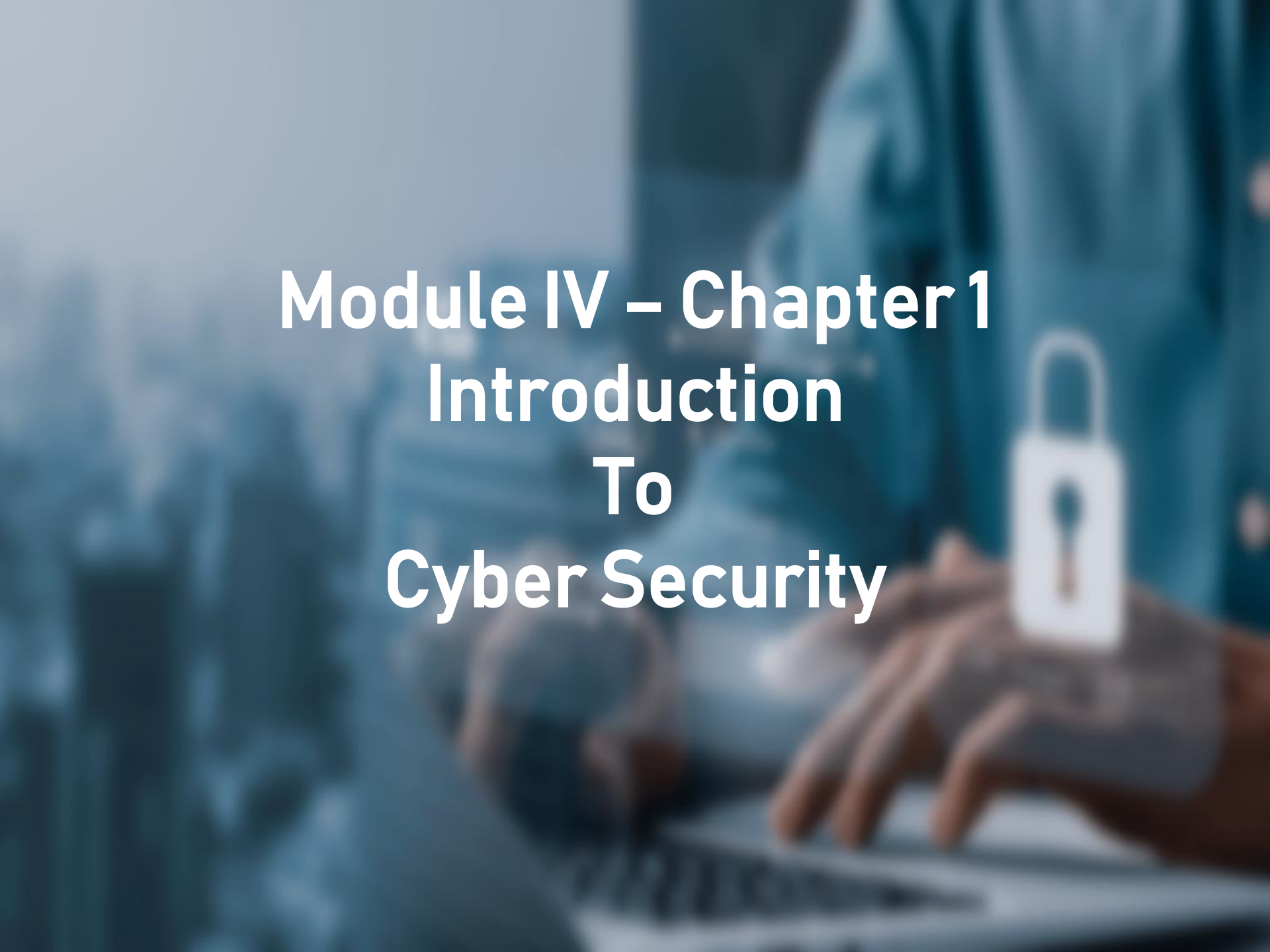




Module IV – Chapter 1

Introduction To Cyber Security

What is email security?

- **Definition:**
Email security refers to the techniques and practices used **to protect email communication systems**, ensuring **confidentiality, integrity, authenticity, and availability** of messages.
- **Importance:**
Email is a fundamental internet service used by billions of users and organizations. Due to its widespread use, it is a primary target for cyber threats such as **phishing, spoofing, malware, and unauthorized access**.

- **Objectives of Email Security:**
 - **Prevent unauthorized access** to email accounts
 - Ensure messages are **not altered during transmission** (integrity)
 - Verify **sender identity** (authenticity)
 - **Maintain continuous access** to email services (availability)
- **Key Mechanisms:**
 - **Security Protocols:**

Standard protocols are implemented in email systems to secure communication. These are supported by platforms like Microsoft Exchange and Microsoft 365.
 - **Encryption & Authentication:**

Protects message content and verifies sender identity during transmission.
 - **Email Security Gateways:**

Act as filters to detect and block spam, phishing attacks, and malicious attachments before they reach users.

Types of email attacks

Email systems have been widely exploited since their inception, leading to various forms of attacks that compromise security and user trust.

1. Phishing

- Phishing is a fraudulent attack where an attacker **impersonates a trusted entity** (e.g., bank or service provider) to steal sensitive information such as passwords or financial details.
- Conducted via fake emails, messages, or websites
- Variants include:
 - **Spear Phishing:** Targets specific individuals
 - **Whaling:** Targets high-level executives or authorities



2. Spoofing

- Email spoofing is a technique in which attackers **manipulate the email header** to appear as if the message is sent from a legitimate or trusted source.
- Misleads recipients into trusting the email
- Often used to deliver malicious links or attachments



3. Spamming

- Spamming involves **sending large volumes of unsolicited and irrelevant emails, usually for advertising purposes.**
- Can overload inboxes
- Often used as a medium to spread phishing attacks or malware



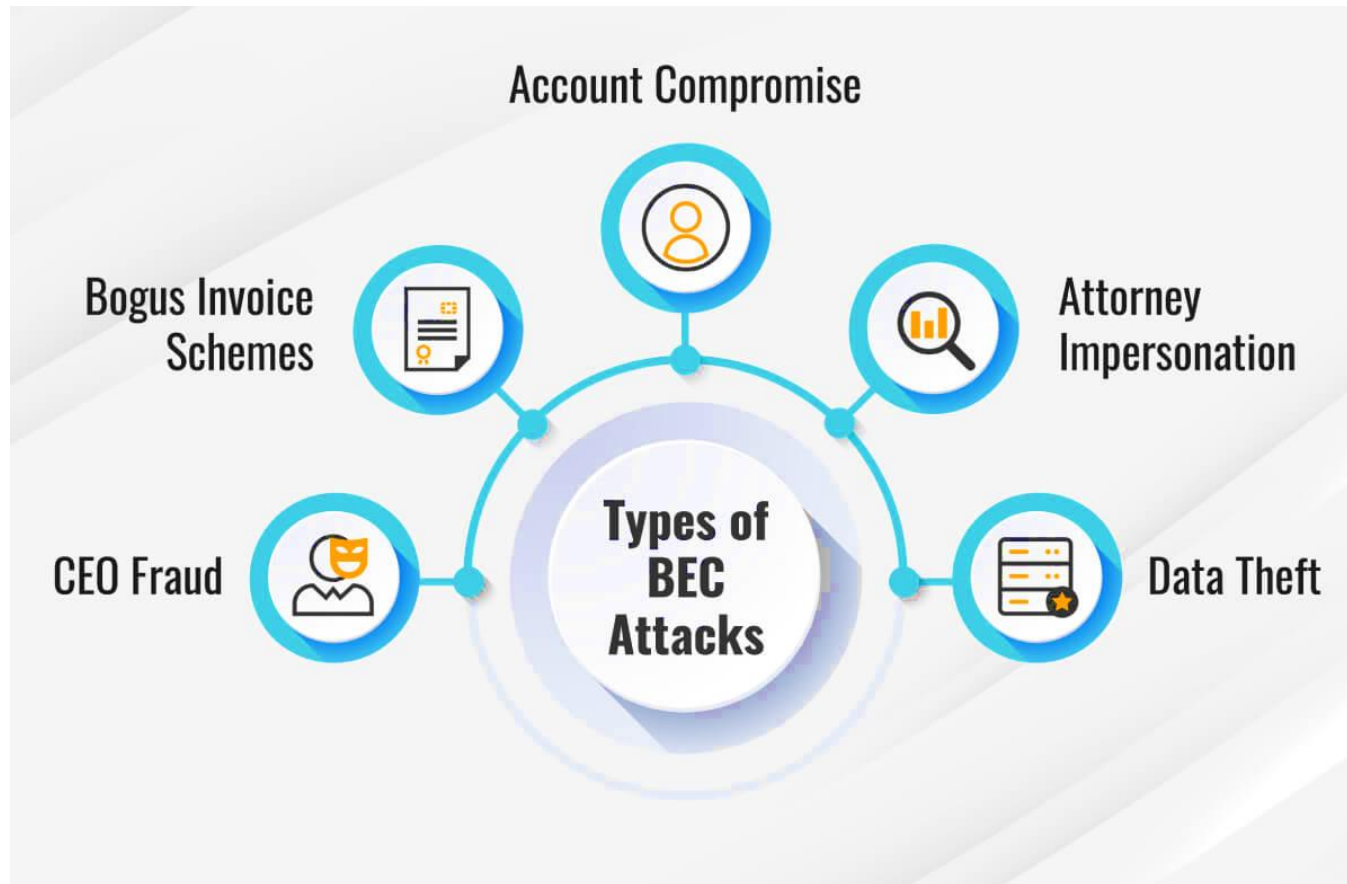
4. Malware Delivery

- Attackers use email as a medium to deliver **malicious software (malware)** designed to damage or exploit systems.
- Delivered via attachments or malicious links
- Common types:



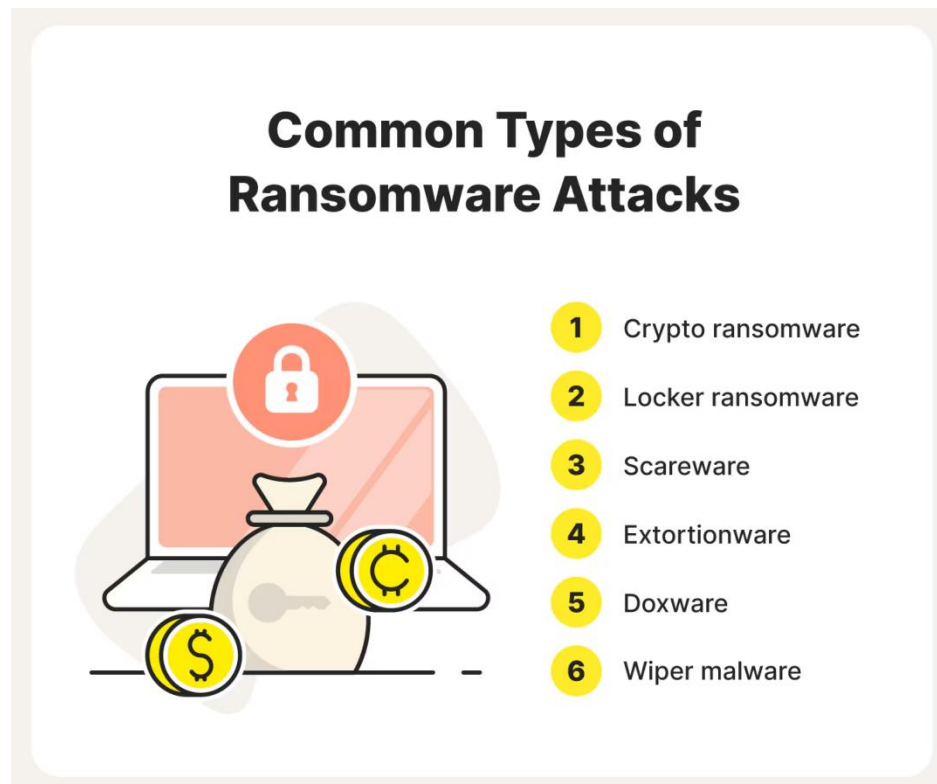
5. Business Email Compromise (BEC)

- BEC is a targeted cyber attack where attackers **impersonate trusted individuals** (e.g., executives or vendors) to manipulate victims.
- Aims to **steal money or sensitive data**
- Often involves social engineering and email spoofing



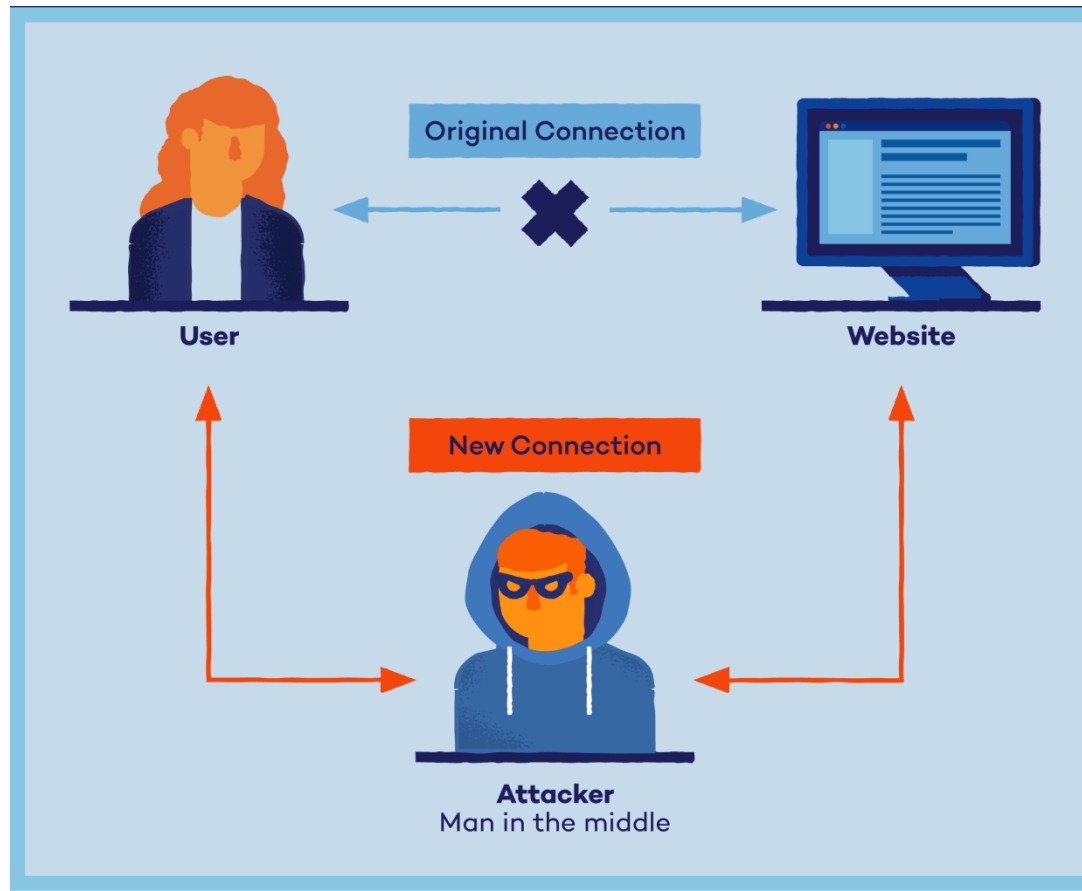
6. Ransomware

- Ransomware is a type of malware that **encrypts a victim's files or systems.**
- Access is denied until a ransom is paid
- Typically spread through malicious email attachments or links



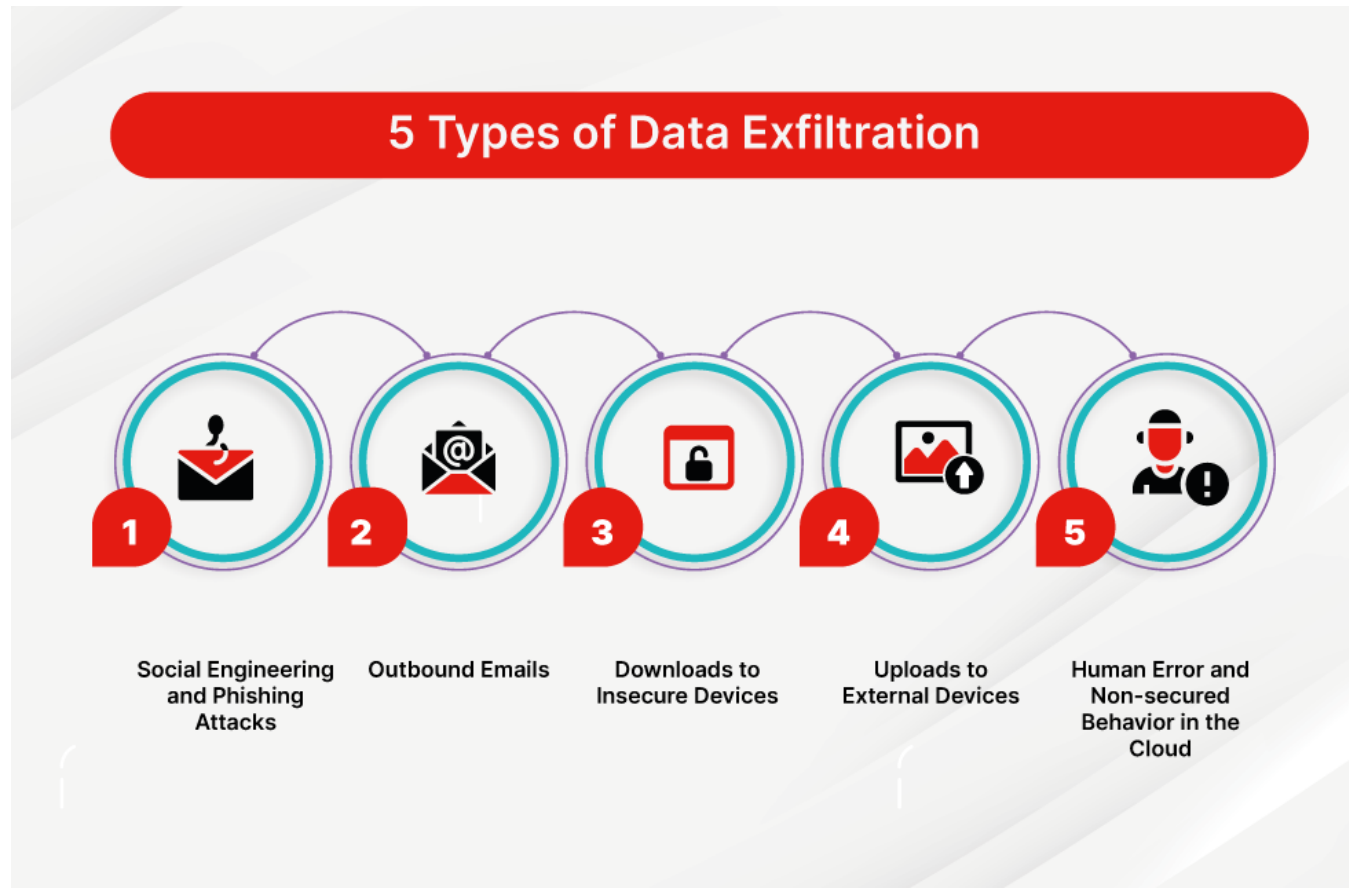
7. Man-in-the-Middle (MitM) Attack

- In a MitM attack, the attacker intercepts communication between two parties.
- Eavesdrops or alters messages
- Victims believe they are communicating directly with each other

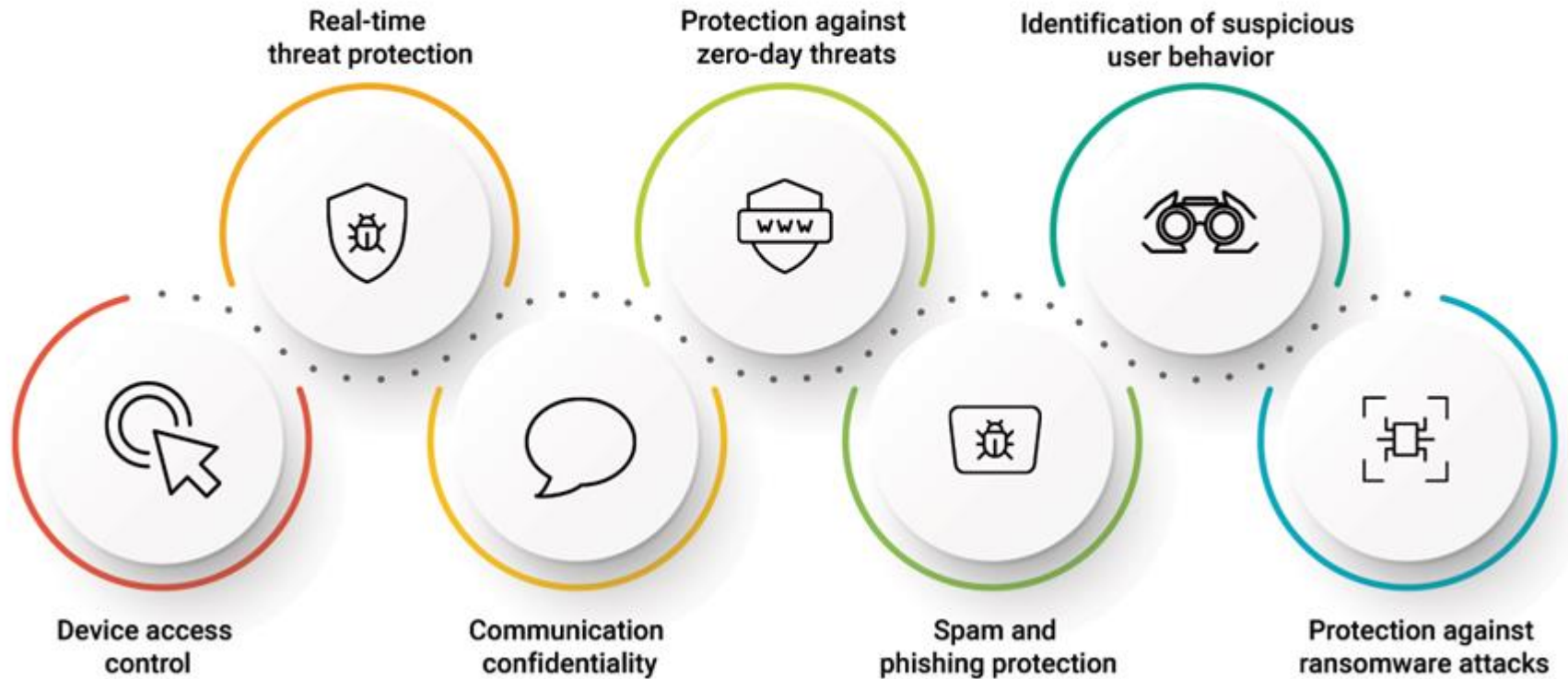


8. Data Exfiltration

- Data exfiltration involves **unauthorized extraction of sensitive information from an email system.**
- Often carried out silently over time
- Targets confidential business or personal data



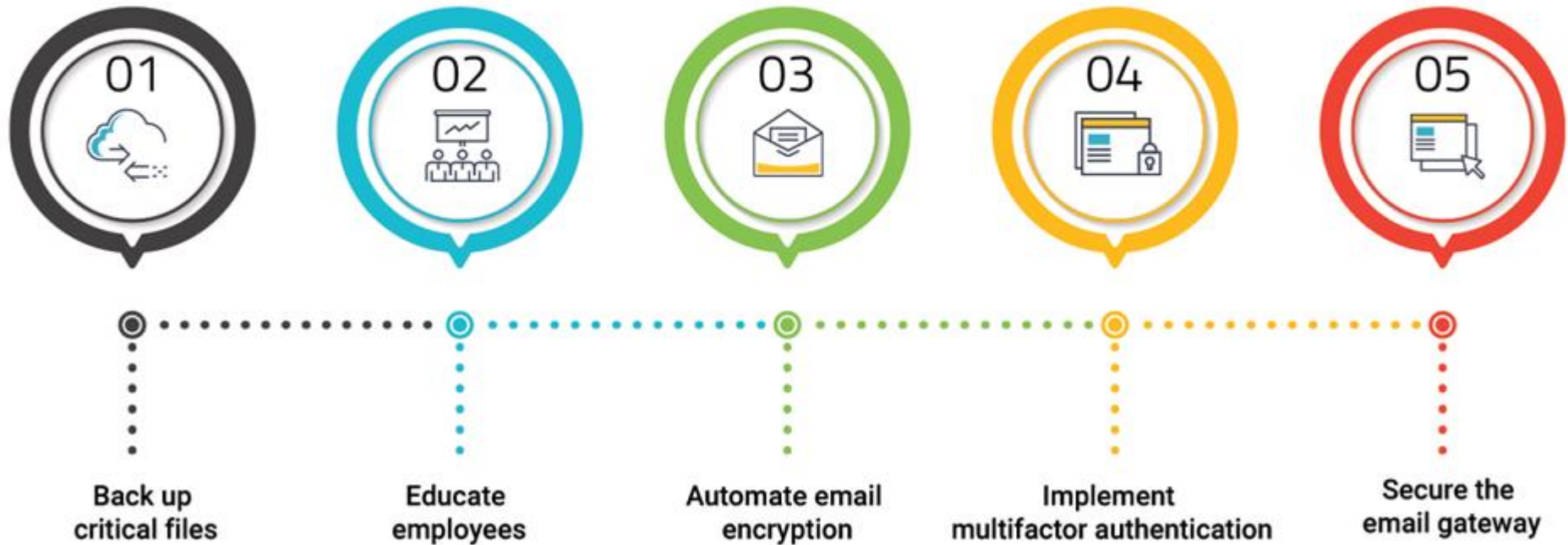
BENEFITS OF EMAIL SECURITY FOR ENTERPRISES



What are the benefits of email security for businesses?

- **Availability.**
 - At the most basic level, email security can help to ensure the continued availability of email services so a business can continue to communicate with its employees and customers.
- **Authenticity.**
 - Having email authenticity measures in place can help to build trust for an organization and its users that email coming from its domain is authentic.
- **Fraud prevention.**
 - The ability to identify potential email and cyber security risks, such as spoofing, can potentially help an organization to reduce the opportunity for fraud.
- **Malware prevention.**
 - An appropriate set of security capabilities in place on an email platform can limit the risks of malware transmitted by email.
- **Phishing protection.**
 - Social engineering tactics, such as phishing attacks, can trick employees to click on links or download items that could be harmful and lead to information disclosure and credential theft. Email security products use techniques to recognize and block phishing emails, shielding people and businesses against fraud and identity theft.
- **Real-time defense.**
 - Email security programs that include antimalware and antispam protection can offer real-time defense against zero-day exploits.

BEST PRACTICES FOR EMAIL SECURITY



Email security best practices

- Enforce encrypted connections.
- Encrypt email.
- Create strong passwords.
- Use two-factor authentication (2FA) or multifactor authentication (MFA).
- Train on anti-phishing.
- Use domain authentication.
 - The use of domain authentication protocols and techniques, including Domain-based Message Authentication, Reporting and Conformance, can help to reduce the risk of domain spoofing.
- Employ a secure email gateway.
 - A secure email gateway acts as a barrier, filtering incoming and outgoing emails for potential cyber threats, such as malware, phishing attempts and spam.
- Use secure Wi-Fi networks.

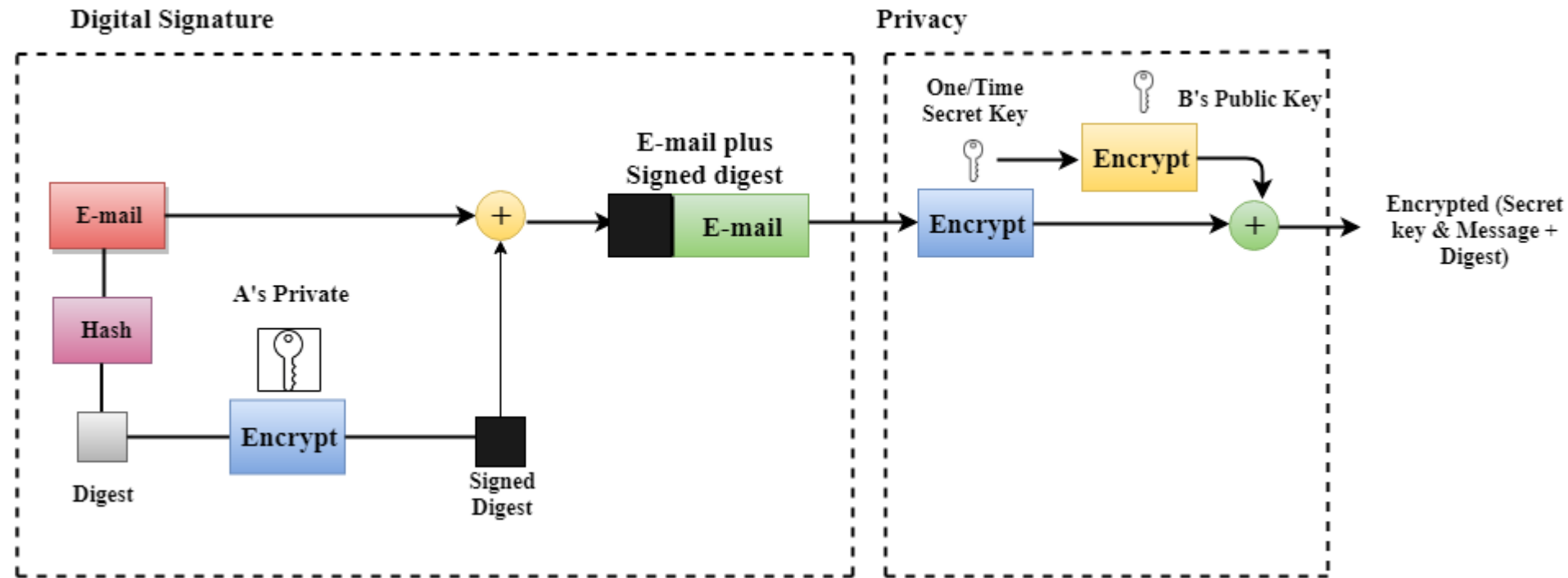
Email security tools

- **Integrated online email service provider platforms.**
 - Microsoft Exchange Online, which is part of the Microsoft 365 Business Standard suite, provides users with an integrated set of email security capabilities.
 - Similarly, Google Workspace offers an enterprise supported version of Gmail that integrates email security as part of the online service.
 - Both Microsoft and Google services provide integrated antimalware and anti spam capabilities, as well as options for encrypted data transit.
- **Email security gateways.**
 - Email security gateways are available from numerous vendors, including Barracuda, Cisco, Forcepoint, Fortinet, Mimecast, Proofpoint and Sophos.
- **Malware and antivirus.**
- **Spam and phishing detection.**
- **Email encryption.**
- **Data loss prevention.**
- **Anti-spoofing.**
- **Reporting and analytics.**

PGP

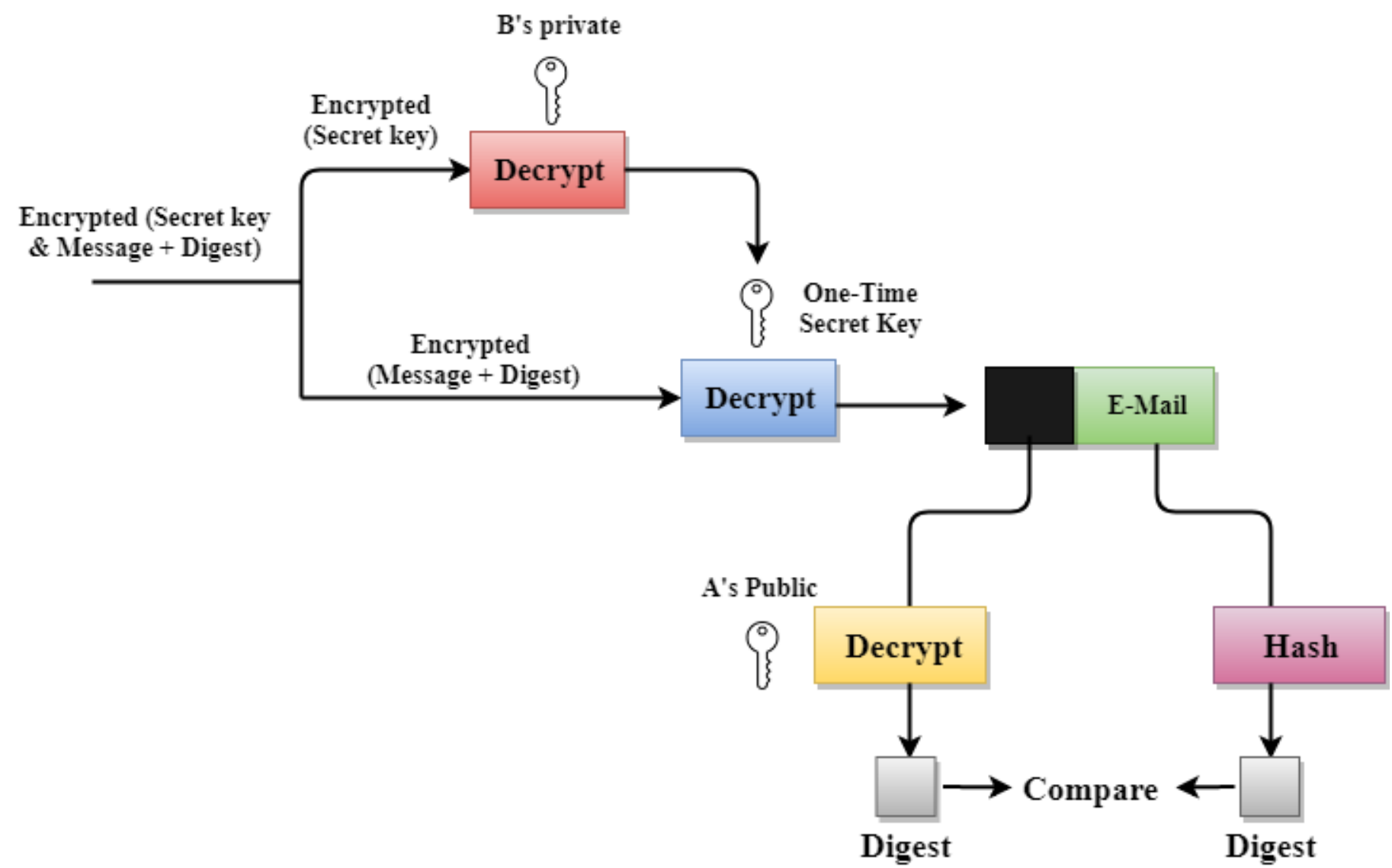
- PGP stands for **Pretty Good Privacy (PGP)** which is invented by **Phil Zimmermann**.
- PGP was designed to provide all four aspects of security, i.e., **privacy, integrity, authentication, and non-repudiation** in the sending of email.
- PGP uses a digital signature to provide integrity, authentication, and non-repudiation.
- PGP uses a combination of secret key encryption and public key encryption to provide privacy.
- Therefore, we can say that **the digital signature uses one hash function, one secret key, and two private-public key pairs**.
- PGP is an **open source** and **freely available software package** for email security.
- PGP **provides authentication** through the use of Digital Signature.
- It **provides confidentiality** through the use of symmetric block encryption.
- It **provides compression by using the ZIP algorithm**, and EMAIL compatibility using the radix-64 encoding scheme.

Following are the steps taken by PGP to create secure e-mail at the sender site:



- The e-mail message is hashed by using a hashing function to create a digest.
- The digest is then encrypted to form a signed digest by using the sender's private key, and then signed digest is added to the original email message.
- The original message and signed digest are encrypted by using a one-time secret key created by the sender.
- The secret key is encrypted by using a receiver's public key.
- Both the encrypted secret key and the encrypted combination of message and digest are sent together.

Following are the steps taken to show how PGP uses hashing and a combination of three keys to generate the original message:



- The receiver receives the combination of encrypted secret key and message digest is received.
- The encrypted secret key is decrypted by using the receiver's private key to get the one-time secret key.
- The secret key is then used to decrypt the combination of message and digest.
- The digest is decrypted by using the sender's public key, and the original message is hashed by using a hash function to create a digest.
- Both the digests are compared if both of them are equal means that all the aspects of security are preserved.

3 uses of PGP Encryption



Encrypting Emails



**Digital Signature
Verification**



Encrypting Files

Advantages Of PGP encryption

- **Strong Encryption:** PGP uses robust encryption algorithms, ensuring data privacy.
- **User Control:** Users control their keys, which enhances trust and reduces reliance on third parties.
- **Integrity and Authentication:** Through digital signatures and hash functions, PGP provides data integrity and verifies the authenticity of the sender.
- **Wide Adoption:** PGP is widely accepted and used across various platforms and applications for secure communication.

Disadvantages of PGP Encryption

- **The Administration is difficult:** The different versions of PGP complicate the administration.
- **Compatibility issues:** Both the sender and the receiver must have compatible versions of PGP.
- **Complexity:** PGP is a complex technique. Other security schemes use symmetric encryption that uses one key or asymmetric encryption that uses two different keys.
- **No Recovery:** Computer administrators face the problems of losing their passwords. In such situations, an administrator should use a special program to retrieve passwords.

MIME Protocol

- MIME stands for **Multipurpose Internet Mail Extensions**.
- It is used to **extend the capabilities of Internet e-mail protocols such as SMTP**.
- MIME is an **e-mail extension protocol**, i.e., it does not operate independently, but it helps to extend the capabilities of e-mail in collaboration with other protocols such as SMTP.
- The MIME protocol allows the **users to exchange various types of digital content such as pictures, audio, video, and various types of documents and files in the e-mail**.
- MIME was **created in 1991 by** a computer scientist named **Nathan Borenstein** at a company called **Bell Communications**.
- At present, it is used by almost all e-mail related service companies such as Gmail, Yahoo-mail, Hotmail.

Need of MIME Protocol

MIME protocol is used to transfer e-mail in the computer network for the following reasons:

- The MIME protocol **supports multiple languages** in e-mail, such as Hindi, French, Japanese, Chinese, etc.
- Simple protocols **can reject mail that exceeds a certain size, but there is no word limit** in MIME.
- **Images, audio, and video cannot be sent using simple e-mail protocols such as SMTP. These require MIME protocol.**

Features of MIME Protocol

- It supports **multiple attachments in a single e-mail.**
- It supports the **non-ASCII characters.**
- It supports **unlimited e-mail length.**
- It supports **multiple languages.**

MIME Header

1. MIME Version

- It defines the version of the MIME protocol. This header usually has a parameter value 1.0, indicating that the message is formatted using MIME.

2. Content Type

- It describes the type and subtype of information to be sent in the message. These messages can be of many types such as Text, Image, Audio, Video, and they also have many subtypes such that the subtype of the image can be png or jpeg. Similarly, the subtype of Video can be WEBM, MP4 etc.

3. Content Type Encoding

- In this field, it is told which method has been used to convert mail information into ASCII or Binary number, such as 7-bit encoding, 8-bit encoding, etc.

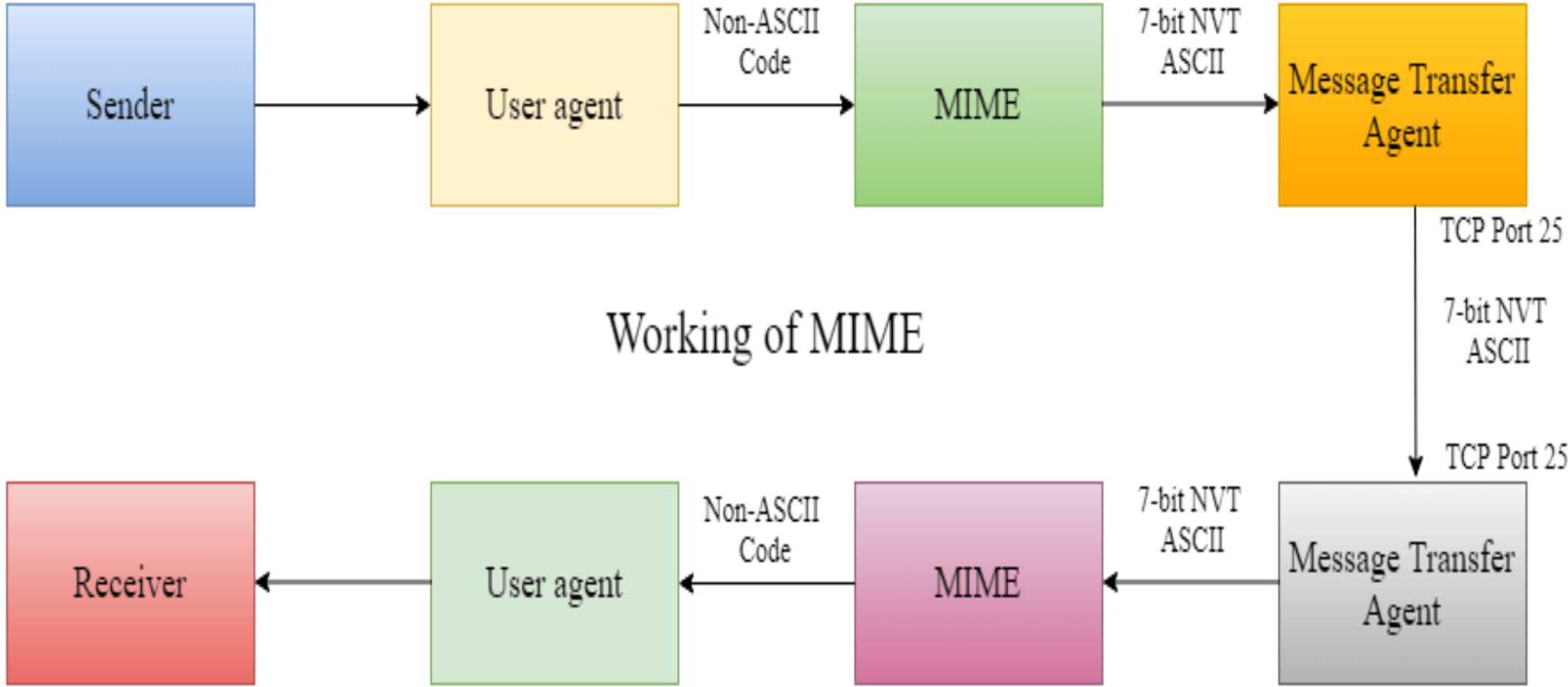
4. Content Id

- In this field, a unique "Content Id" number is appended to all email messages so that they can be uniquely identified.

5. Content description

- This field contains a brief description of the content within the email. This means that information about whatever is being sent in the mail is clearly in the "Content Description". This field also provides the information of name, creation date, and modification date of the file.

Working diagram of MIME Protocol



S/MIME

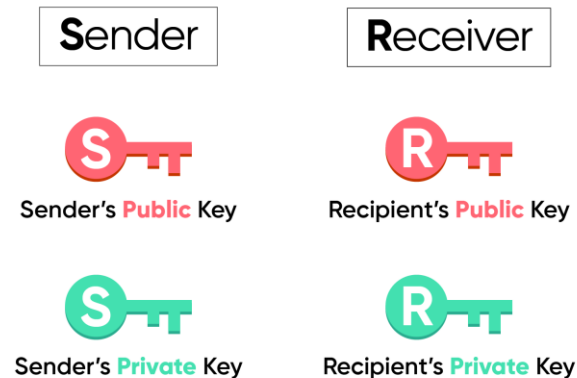
- **S/MIME** stands for **Secure/Multipurpose Internet Mail Extensions**.
- **S/MIME** is a standard used to provide **security for email communication**. It enhances MIME email format by adding cryptographic protection.
- It ensures:
 - **Confidentiality** (encryption)
 - **Integrity** (message not altered)
 - **Authentication** (sender identity verified)
 - **Non-repudiation** (sender cannot deny sending)
- Developed and standardized by organizations like IETF(**Internet Engineering Task Force**)

S/MIME includes two security features:

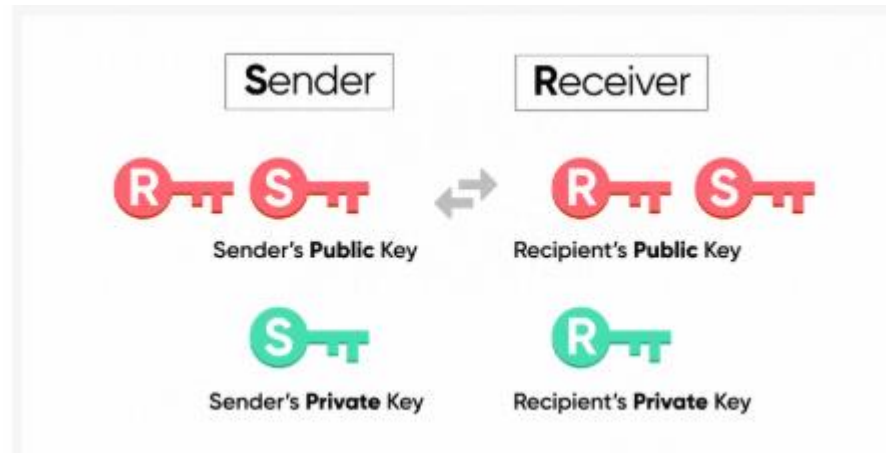
- Email Encryption
- Digital Signature

Pre-requisites for S/MIME

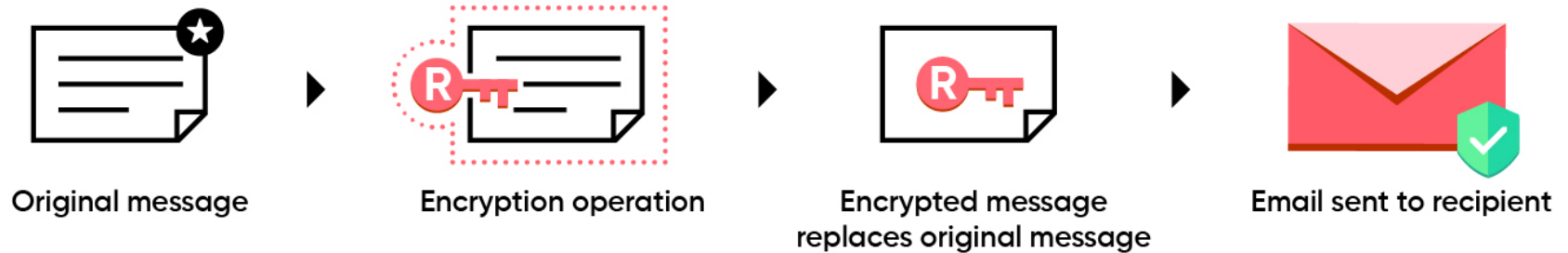
- You need to have a valid S/MIME certificate. This certificate would include a public key and a private key mapped to your email address.



- The sender and the receiver have to exchange their public key with each other. **This process happens automatically when the sender and recipient exchange emails for the first time.**

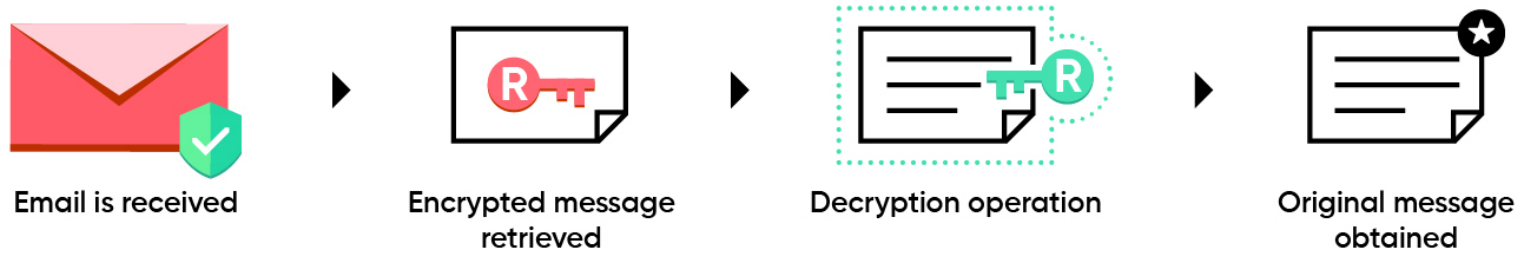


Encryption process:



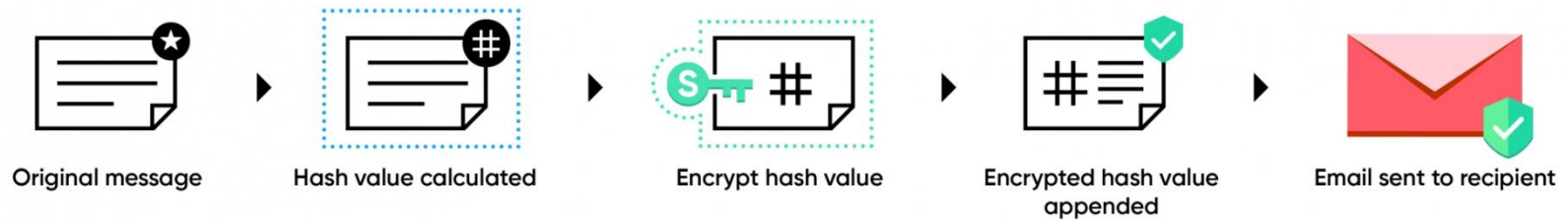
- Once the sender clicks on **Send**, the original unencrypted message is captured.
- The **recipient's public key is used to encrypt** the original message. At the end of the process, an encrypted version of the original message is produced.
- The encryption message replaces the original message.
- The email is sent to the recipient.

Decryption process:



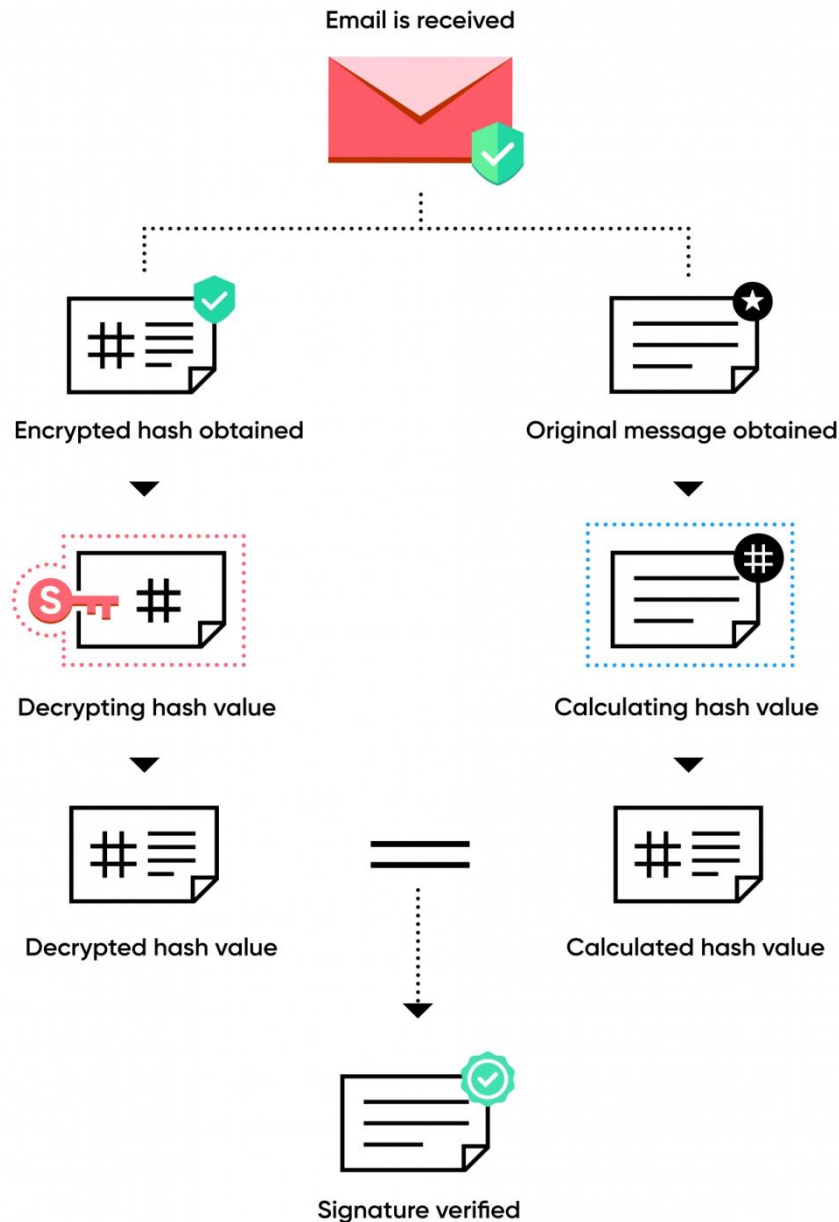
- The recipient receives the email.
- The encrypted message is retrieved.
- The **recipient's private key is used to decrypt** the encrypted message.
- The original message is obtained and displayed to the recipient.

Digital Signature:



1. Once the sender clicks on **Send**, the original message is captured.
2. The message hash is calculated.
3. The **sender's private key is used to encrypt the hash value.**
4. The encrypted hash value is added to the email.
5. The email is sent to the recipient.

Signature verification process:

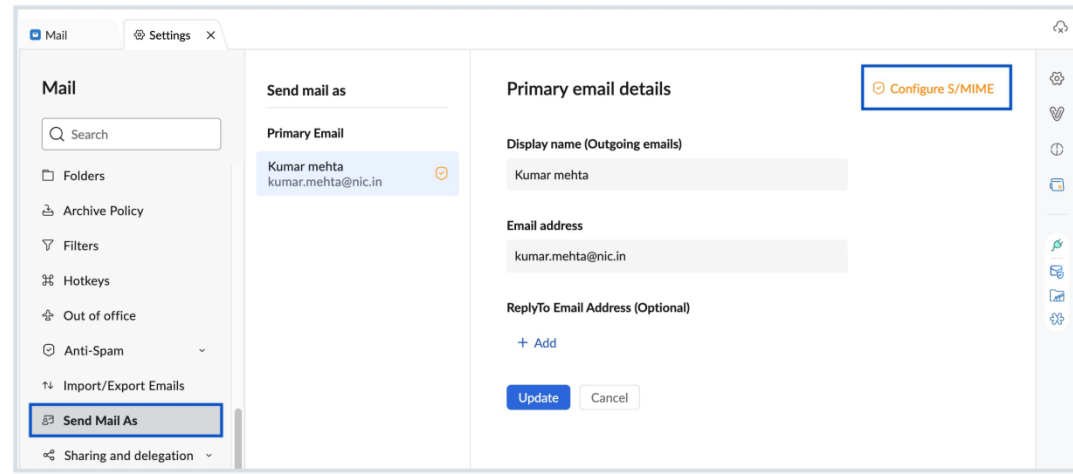
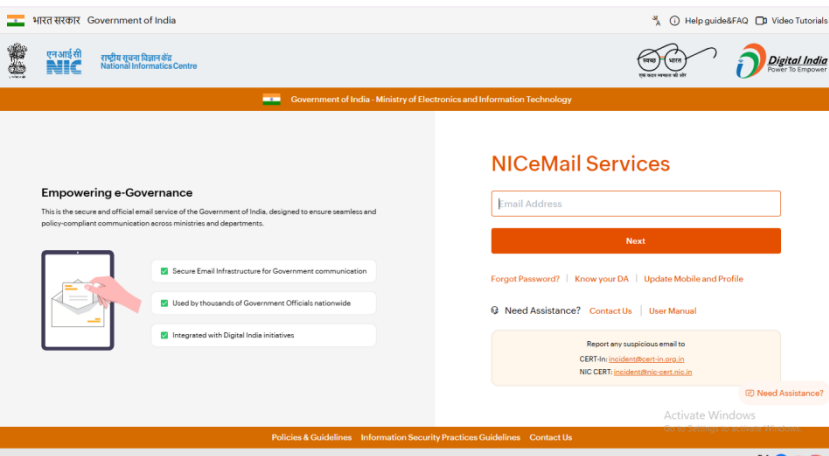


1. The recipient receives the digitally signed email.
2. The original message is obtained and its hash value is calculated.
3. The encrypted hash is retrieved from the email.
4. The encrypted hash is decrypted using the **sender's public key**.
5. The decrypted hash and the hash value calculated from the original message obtained are compared. If the values match, the signature is verified.

Configuring S/MIME

You can configure S/MIME for your email address from the **Send Mail As** settings. To begin configuring S/MIME, you are required to possess a valid certificate mapped to the email account issued by an authenticated certifier.

1. Login to <https://mail.gov.in/>.
2. Click the **Settings** icon.
3. Go to **Send Mail As** setting.
4. Choose the **Configure S/MIME** option next to the email address for which you want to configure S/MIME. The S/MIME encryption popup opens.



5. Click on the **Add certificate** button and select the certificate to upload the S/MIME certificate of the relevant email account.
6. Enter the certificate password and click **Save** to complete the uploading process.

The screenshot shows a web interface for S/MIME encryption. At the top, there is a back arrow and the text "S/MIME encryption kumar.mehta@nic.in". Below this, on the left, is a button labeled "+ Add a Certificate" which is highlighted with a blue border. To the right of this button is a modal dialog box. The dialog box has a close button (X) in the top right corner. It contains two main sections: "Certificate name" and "Certificate password". The "Certificate name" section has a "Choose file" button and the text "No file chosen". The "Certificate password" section has a password input field with a lock icon and a series of dots representing the password. At the bottom of the dialog box are two buttons: "Save" and "Cancel".

7. Once uploaded, select the certificate. Click the **OK** button on the S/MIME certificate popup that appears to enable the certificate.

S/MIME encryption - rebecca@zylker.com

✓



CN='intermediate'

Tue Jan 22 2019



CN='intermediate'

Tue Jan 22 2019



CN='intermediate'

Wed Jan 30 2019



CN='intermediate'

Wed Jan 30 2019

+ Add certificate

Aspect	MIME (Multipurpose Internet Mail Extensions)	S/MIME (Secure MIME)
Purpose	Extends email format to support multimedia content	Adds security to MIME emails
Security	☐ No security features	Provides encryption & digital signatures
Confidentiality	Not supported	Supported (encryption)
Integrity	Not ensured	Ensured using hash + digital signature
Authentication	Not provided	Provided using digital signatures
Non-repudiation	Not available	Available
Encryption	☐ No encryption	Uses symmetric + asymmetric encryption
Digital Signature	☐ Not supported	Supported
Key Management	Not applicable	Uses PKI & certificates
Standards Body	Defined by IETF	Also standardized by IETF
Content Support	Text, images, audio, video attachments	Same as MIME + secured content
Usage	Basic email formatting	Secure email communication

S/MIME vs PGP (Pretty Good Privacy)

- Both **S/MIME** and **PGP** are used for securing email communication.
- **S/MIME** relies on **PKI** and digital certificates issued by a **Certificate Authority (CA)**.
- **PGP** can be used without relying on a central authority and uses a **web of trust** for key distribution.

Practical Use of S/MIME

- Email applications like **Microsoft Outlook**, **Apple Mail**, and **Mozilla Thunderbird** support S/MIME.
- Users can get **digital certificates** from a CA or use self-signed certificates for personal use.
- Once a digital certificate is installed, the user can send encrypted and signed emails easily.

Common Challenges with S/MIME

- **Key Management:** Users must securely manage their private keys and certificates.
- **Certificate Expiration:** Certificates must be renewed periodically.
- **Compatibility:** Both sender and recipient must have compatible email clients and certificates.

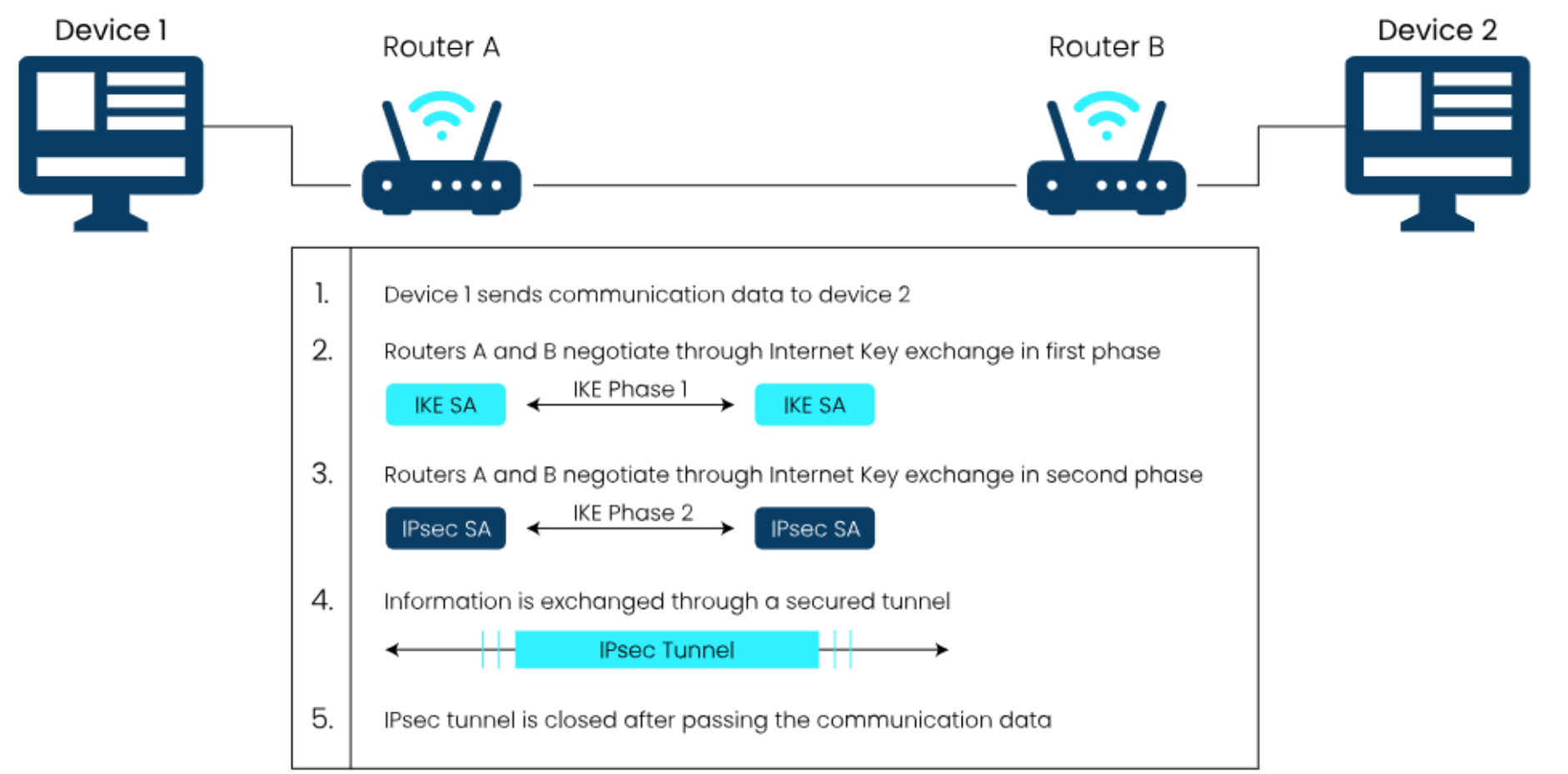
IPSec

- **IPSec** is a network layer security protocol that provides **secure communication over IP networks**.
- It is standardized by IETF (**Internet Engineering Task Force**)
- **Key Services:**
 - **Confidentiality** (encryption)
 - **Integrity** (data not altered)
 - **Authentication** (verifies sender)
 - **Anti-replay protection**
- **Main Protocols**
 - **AH (Authentication Header)**
 - Provides integrity + authentication
 - No encryption
 - **ESP (Encapsulation Security Payload)**
 - Provides encryption + integrity + authentication

What is IPSec encryption?

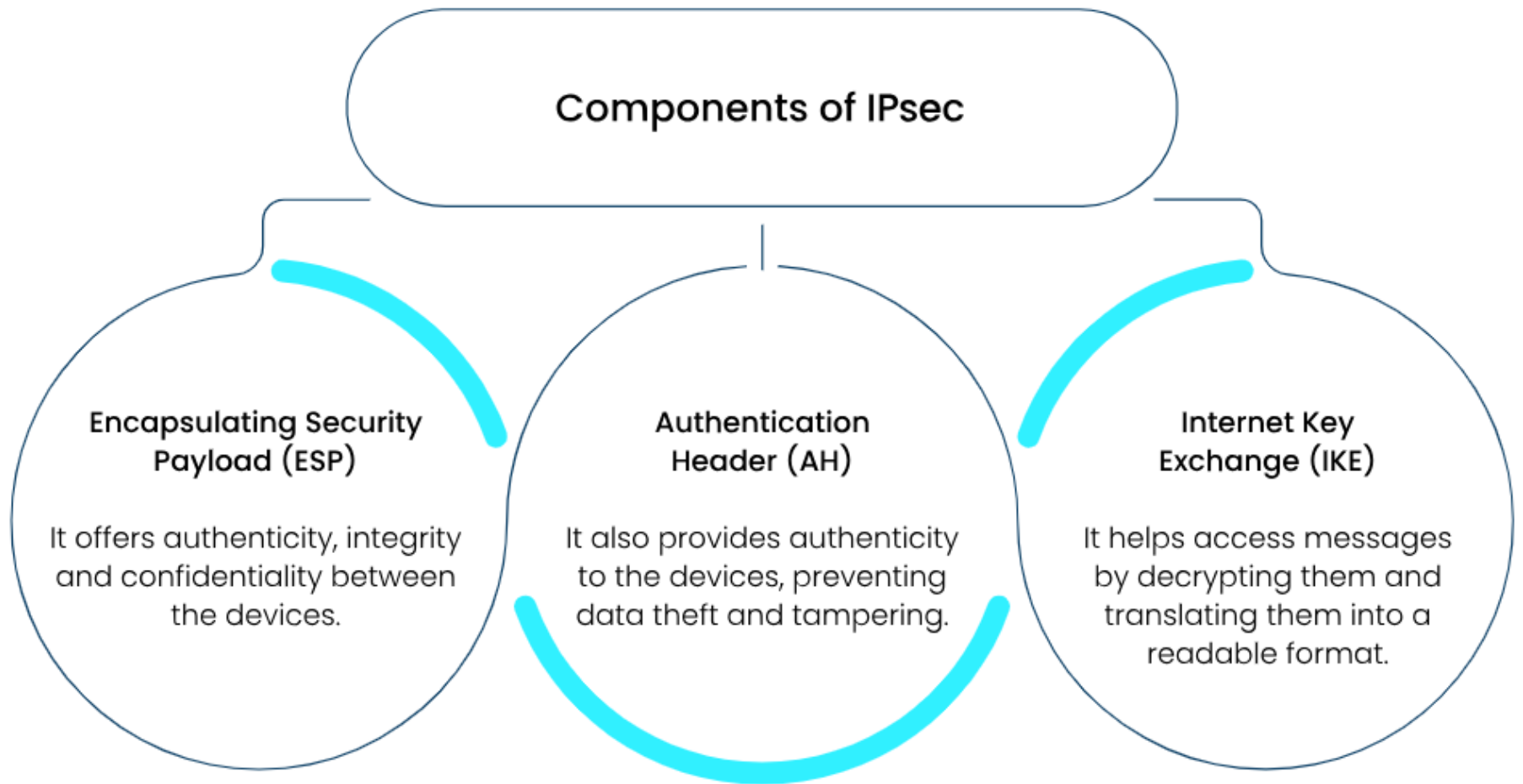
- IPSec encrypts data to keep it safe from unauthorized access
- Uses **keys**:
 - Encryption key → to scramble data
 - Decryption key → to read data
- Supports algorithms: AES, DES, 3DES, Blowfish, ChaCha
- Uses two types of encryption:
 - **Asymmetric encryption** → public key + private key (for secure setup)
 - **Symmetric encryption** → same key (for fast data transfer)
- **Working idea**:
 - First uses asymmetric encryption to establish connection
 - Then switches to symmetric encryption for faster communication

How does IPSec work?



- **Host Recognition**
 - System identifies data that needs security (**interesting traffic**)
 - Outgoing → encrypted
 - Incoming → verified
- **IKE Phase 1 (Setup)**
 - Devices establish secure connection
 - Agree on algorithms & exchange keys
 - Creates **Security Association (SA)**
- **IKE Phase 2 (SA Creation)**
 - Separate SAs for sending & receiving
 - Defines protocol (AH/ESP), keys, algorithms
- **Data Transmission**
 - Actual data is sent securely
 - Uses SAs for encryption & decryption
- **Termination**
 - Tunnel ends after time/data limit
 - Keys are deleted

Components of IPsec



1. Encapsulation Security Payload (ESP):

- **ESP** is an IPSec protocol that provides:
 - **Confidentiality** (encryption)
 - **Integrity** (no data tampering)
 - **Authentication**
- **Encryption:**
 - Converts readable data → unreadable form
 - Only authorized users can decrypt and read it
- **ESP Authentication:**
 - Ensures data is not modified
 - Authenticates the sender
- **Important Point:** Protects **payload (data)**, not the IP header

2. Authentication Header (AH):

- **AH** provides:
 - **Integrity** (prevents data tampering)
 - **Authentication** (verifies sender)
 - **Anti-replay protection**
- **Important Points:**
 - **No encryption** → data remains readable
 - Protects packet, but **does not hide content**
 - Sender and receiver identities are visible
- **Comparison Note:**
 - AH → No confidentiality
 - ESP → Provides confidentiality (encryption)

3. IKE (Internet Key Exchange)

- **IKE** is used in IPSec to:
 - **Create Security Associations (SA)**
 - **Exchange keys securely**
- Ensures only sender and receiver can access data
- **Key Features:**
 - Automatically generates and manages keys
 - Supports **strong and customizable keys**
 - **Regularly updates keys** for better security

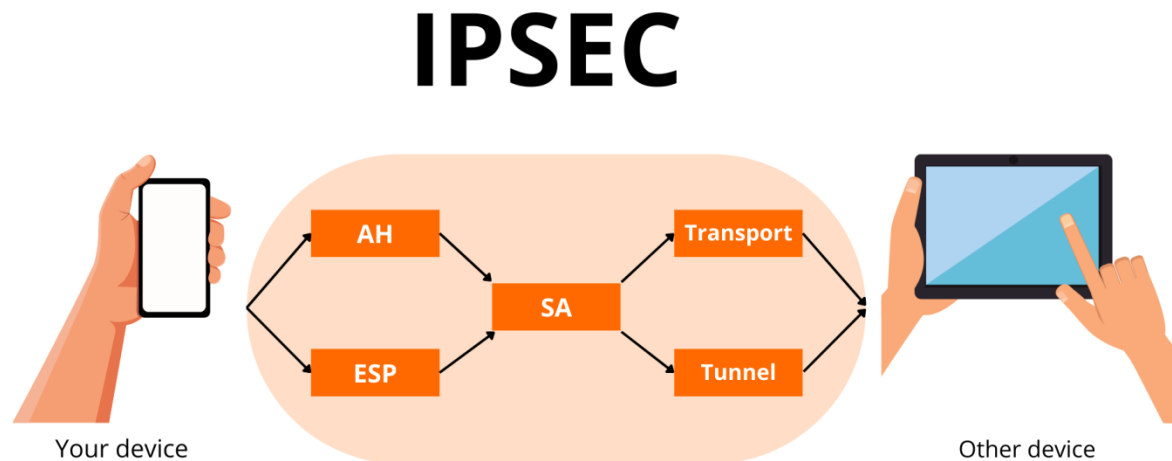
What are IPSec modes?

- **Tunnel**

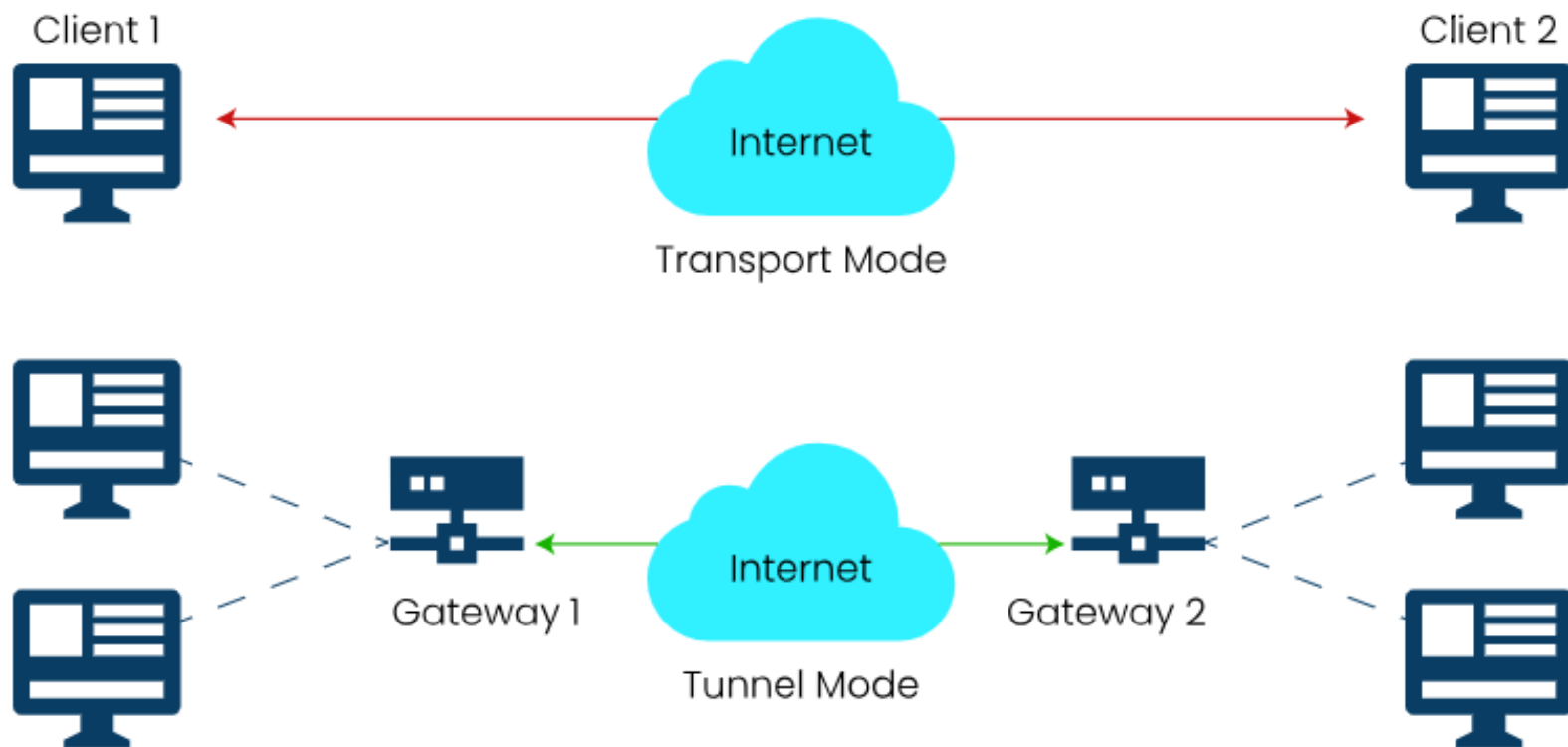
- The IPSec tunnel mode is suitable for transferring data on public networks as it enhances data protection from unauthorized parties. The computer **encrypts all data, including the payload and header, and appends a new header to it.**

- **Transport**

- IPSec transport mode **encrypts only the data packet's payload and leaves the IP header in its original form.** The unencrypted packet header allows routers to identify the destination address of each data packet. Therefore, IPSec transport is used in a close and trusted network, such as securing a direct connection between two computers.



IPsec Modes



Advantages of IPsec

IPsec provides the following benefits:



Disadvantages of IPsec

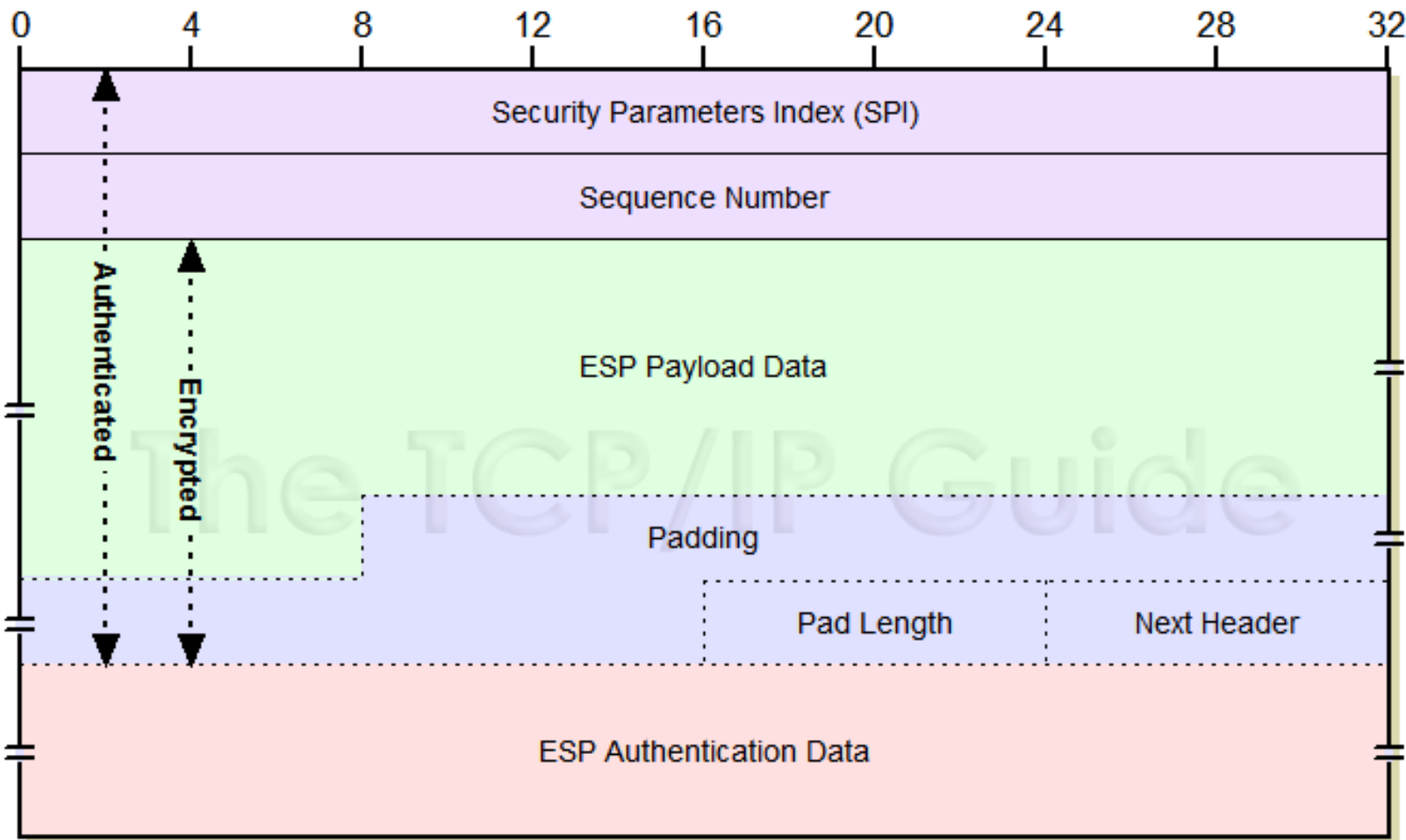
The following are IPsec's disadvantages:



Encapsulating Security Payload (ESP)

- Encapsulating Security Payload (ESP) is a protocol within the IPsec (Internet Protocol Security) suite that provides security services for IP packets, mainly focusing on **confidentiality, data integrity, and optional authentication**.
- **Confidentiality:**
ESP encrypts the payload (data part) of the IP packet, making it **unreadable to unauthorized users**. Common encryption algorithms used include **AES and 3DES**. This protects the data from being seen by attackers during transmission.
- **Authentication and Integrity (Optional):**
ESP can also ensure that the data has **not been altered during transit and verify the identity of the sender**. This is done using hashing algorithms like **HMAC-SHA**, providing protection against data tampering and forgery.
- **Anti-Replay Protection:**
ESP includes a sequence number field to prevent replay attacks, where an attacker resends old packets to disrupt communication.

ESP Format



- **Security Parameters Index (32 bits):** Identifies the Security Association (SA); value 0 is reserved and not transmitted.
- **Sequence Number (32 bits):** Incremental counter for anti-replay protection; starts at 1.
- **Payload Data (variable):** Encrypted data (transport segment or full IP packet in tunnel mode).
- **Padding (0–255 bytes):** Added to match encryption block size and alignment.
- **Pad Length (8 bits):** Specifies number of padding bytes.
- **Next Header (8 bits):** Indicates type of data in payload.
- **Authentication Data (variable):** Optional field containing integrity check value (ICV).

Modes of Operation:

ESP works in two modes:

- **Transport Mode:** Encrypts (and optionally authenticates) only the transport layer data (TCP/UDP); used for host-to-host communication.
- **Tunnel Mode:** Encrypts (and optionally authenticates) the entire IP packet and encapsulates it with a new IP header; used in VPNs.

Weaknesses of Encapsulating Security Protocol

- Encryption Key Management
- Performance Overhead
- Complex Configuration
- Limited Confidentiality of Packet Headers
- Scalability

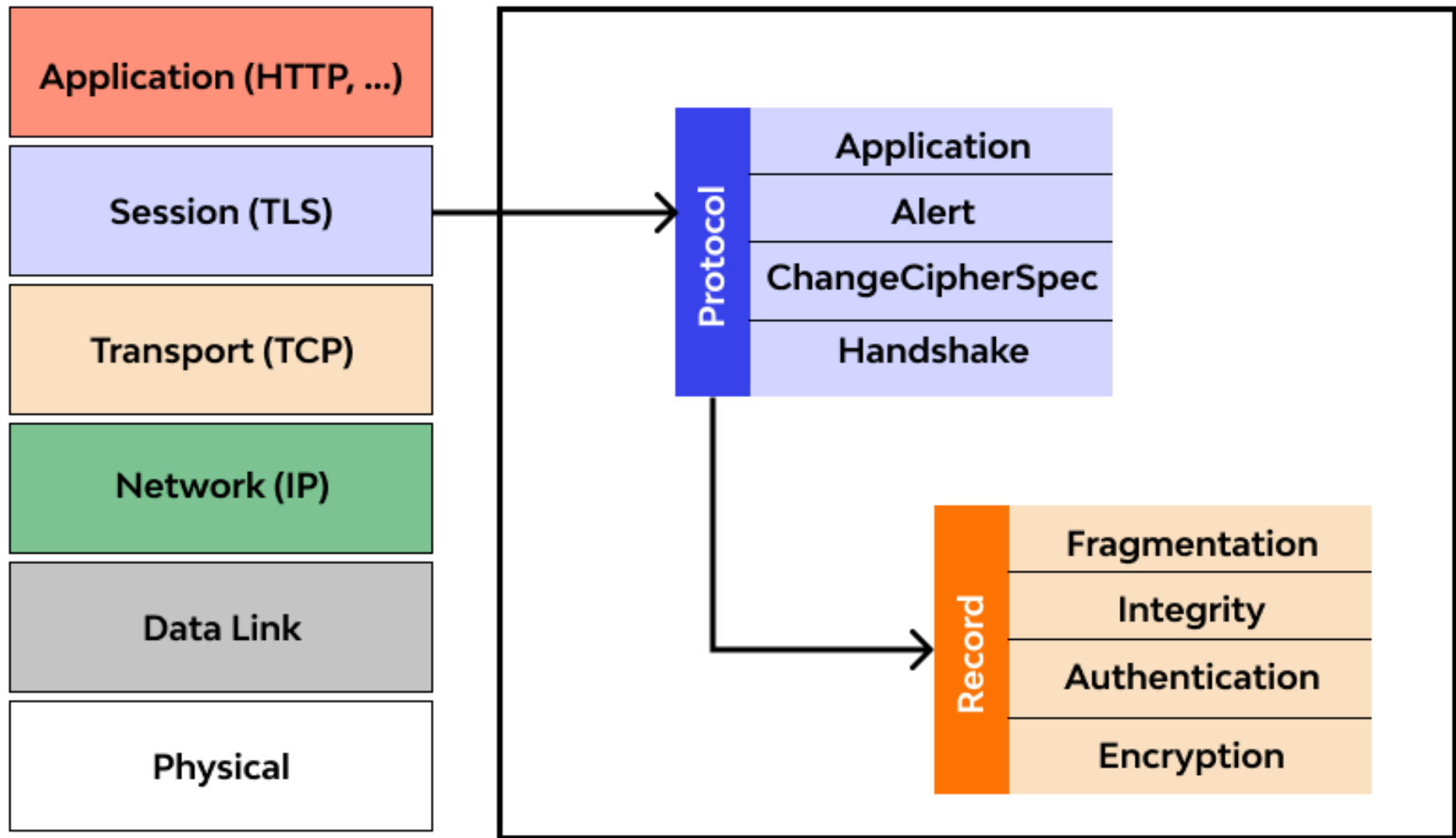
Transport Layer Security (TLS)

- **Transport layer security protocol** is one of the security protocols which are designed to **facilitate privacy and data security for communications over the Internet**.
- The main use of TLS is to **encrypt the communication between web applications and servers**, like web browsers loading a website.
- TLS is used to **encrypt other communications like email, messaging, and voice over IP (VoIP)**.
- TLS was proposed by the Internet Engineering Task Force (IETF), which is an international standards organization.

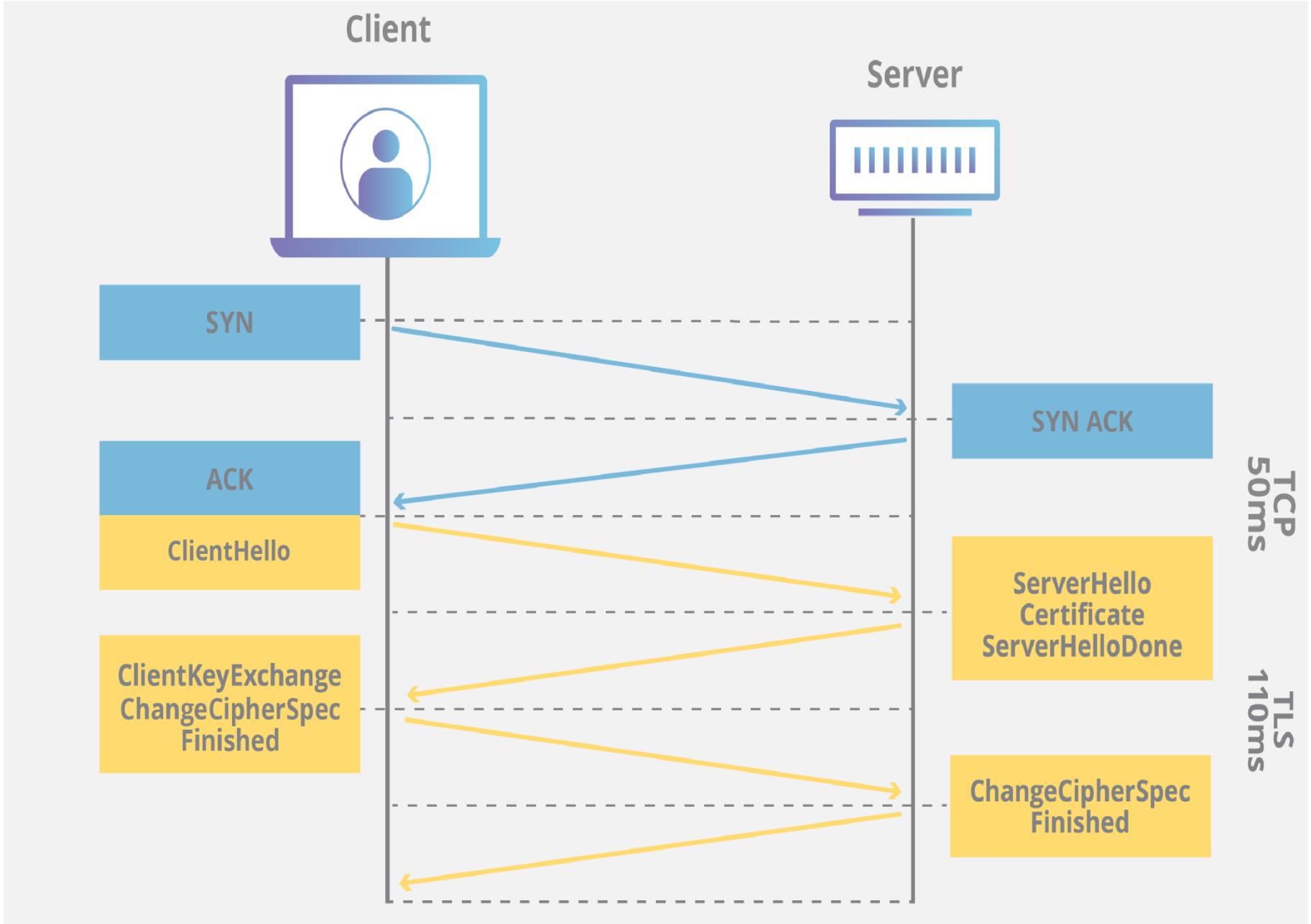
Components:

The three main components that TLS accomplishes are as follows

- **Encryption** It is used to hide the data being transferred from third parties.
- **Authentication** It always ensures that the parties exchanging information are who they claim to be.
- **Integrity** verifies that the data has not been tampered with.



Transport Layer Security (TLS) Handshake Protocol



- A client sends a synchronous message "client hello" requesting a connection and presents a list of supported cipher suites and a random string of bytes.
- The server responds with a "server hello" message containing a server certificate.
- The server is sending its SSL certificate to the client for the purpose of authentication. The client then authenticates the server by verifying the server's SSL certificate, and also sends a certificate for authentication if requested by the server.
- The client sends the client key exchange, change Cipher specification finished message to the server.
- The server decrypts the message sent by client secret with the private key.
- Both client and server generate session keys from the client random, the server random, and the secret message.
- The client sends a "finished" message that has been encrypted with a session key.
- The server responds with a finished message which was encrypted with a session key.
- The client and server have successfully achieved secure symmetric encryption, meaning the handshake is complete and communication can continue with the established session keys.
- Finally transfer the application data.

Secure Socket Layer (SSL)

- Secure Socket Layer (SSL) is a cryptographic protocol designed to **provide secure communication over a computer network**, most commonly the internet.
- It **ensures the confidentiality and integrity of data exchanged** between a user's web browser and a website server.
- SSL **operates by encrypting the data transmitted**, making it unreadable to anyone attempting to intercept the information.
- Originally **developed by Netscape**, SSL has become a fundamental component of modern web security.
- It **establishes a secure connection** through a process called the **SSL Handshake**, where the **server and client authenticate each other** and agree on **cryptographic algorithms and keys**.
- SSL is now **succeeded by its successor, Transport Layer Security (TLS)**, although the terms SSL and TLS are often used interchangeably.

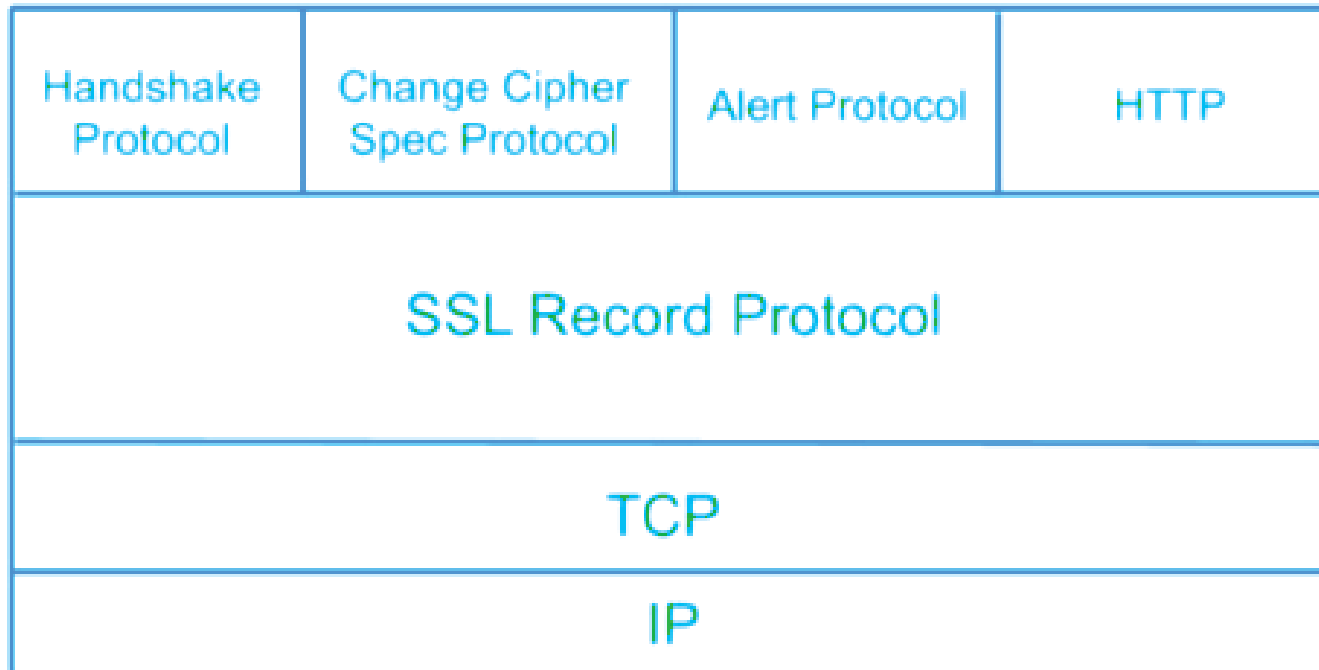
What is Secure Socket Layer (SSL)?

- Secure Socket Layer (SSL) is a cryptographic protocol that provides a **secure and encrypted connection between a client (such as a web browser) and a server (such as a website).**
- Its primary purpose is to **ensure the confidentiality, integrity, and authenticity of data exchanged** between these two entities over the internet.
- SSL achieves this by using encryption algorithms to scramble the data, making it unintelligible to anyone intercepting the communication.



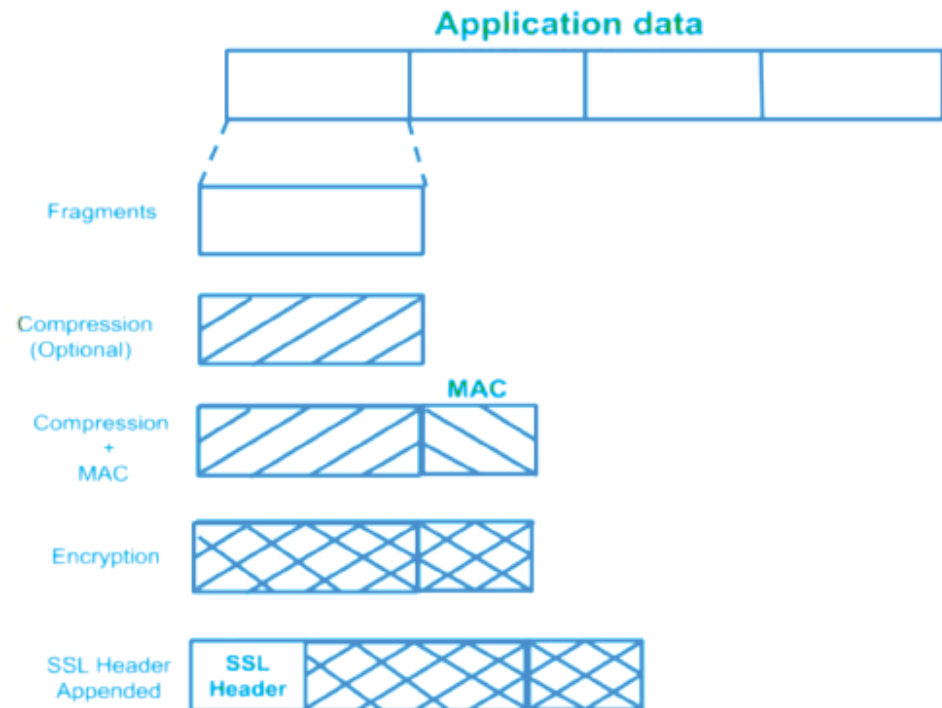
Understanding Secure Socket Layer (SSL) Protocols

- There are various protocols in a SSL layer.



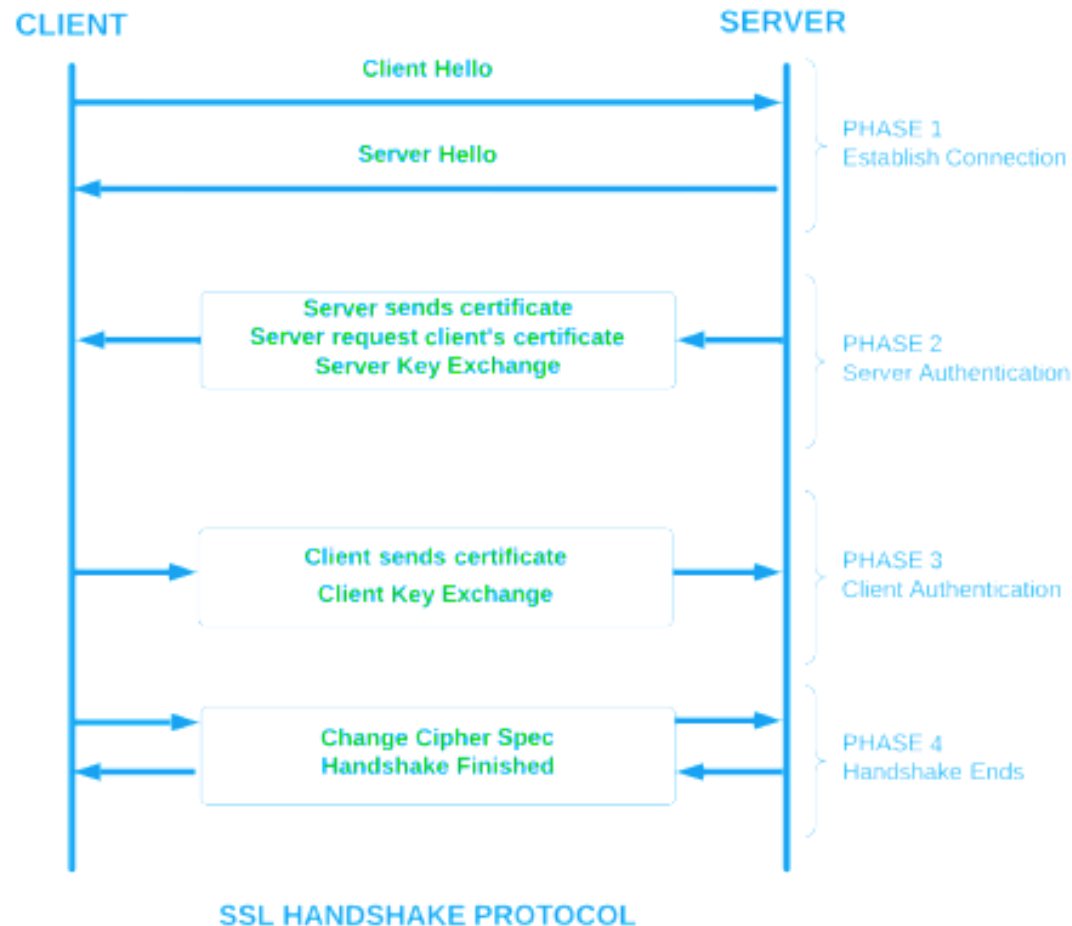
1. SSL Record Protocol

- At the **heart of the SSL protocol** stack lies the SSL Record Protocol.
- This protocol furnishes two essential services to SSL connections: **confidentiality and message integrity**.
- The SSL Record Protocol ensures that data transmitted between a client and a server **remains confidential** and that any tampering or unauthorized modification of the data is detected.
- The application data is divided into fragments, which undergo compression before encryption.
- To bolster integrity, a Message Authentication Code (MAC) is generated using algorithms like SHA (Secure Hash Protocol) and MD5 (Message Digest), and it's appended to the compressed fragment.
- Encryption of the data follows, and finally, an SSL header is attached to the encrypted data.



Handshake Protocol

- The Handshake Protocol is instrumental in establishing secure sessions between clients and servers.
- This protocol enables both entities to authenticate each other by exchanging a series of messages.



Understanding Secure Socket Layer (SSL) Handshake

The foundation of SSL lies in the SSL handshake, a process that establishes a secure connection between a client and a server. The handshake involves a series of steps:

- 1. Client Hello:** The client initiates the handshake by sending a "Client Hello" message, which includes supported SSL/TLS versions and encryption algorithms.
- 2. Server Hello:** The server responds with a "Server Hello" message, selecting the highest mutually supported SSL/TLS version and encryption algorithm.
- 3. Certificate Exchange:** The server presents its digital certificate, which contains its public key and other relevant information. The client validates this certificate against trusted certificate authorities (CAs).
- 4. Key Exchange:** Both client and server agree on a session key using asymmetric encryption, which will be used for symmetric encryption during data transmission.
- 5. Cipher Suite Agreement:** The client and server agree on a cipher suite that includes encryption algorithms, hash functions, and key exchange methods.
- 6. Finished:** The handshake concludes with a "Finished" message, indicating that subsequent data will be encrypted using the agreed-upon parameters.

2. Change-Cipher Protocol

- The Change-Cipher Protocol consists of a single 1-byte message, with the sole purpose of moving the pending state to the current state.

1 byte

3. Alert Protocol

- In the intricate web of SSL communication, the Alert Protocol serves as the bearer of SSL-related alerts to the peer entity. Each message within this **protocol is composed of two bytes**, contributing to the notification of events and issues that affect the SSL connection. These alerts are classified into two levels:

Level
(1 byte)

Alert
(1 byte)

1. **Warning (level 1):** These alerts **do not disrupt the connection between sender and receiver**. Examples include alerts for a bad certificate, absence of a certificate, certificate expiration, and more. The "close notify" alert signifies the sender's intention to cease sending messages in the connection.
2. **Fatal Error (level 2):** Fatal alerts **lead to the termination of the connection, rendering it irreparable**. Instances include a handshake failure, decompression failure, illegal parameters, and the receipt of an unexpected message.

The second byte in the Alert Protocol serves as a descriptor of the specific error or alert encountered.

Importance of SSL/TLS in Today's Digital World

1. Data Privacy:

SSL/TLS encryption ensures that sensitive data, such as credit card information and personal details, remains private and cannot be intercepted by malicious actors.

2. Trust and Authenticity:

SSL certificates establish the legitimacy of websites and assure users that they are interacting with the intended server rather than a malicious impersonator.

3. SEO and Browser Compatibility:

Search engines like Google consider SSL/TLS as a ranking factor. Additionally, many modern browsers flag non-secure websites, influencing user trust and accessibility.

4. Regulatory Compliance:

Many industries, such as finance and healthcare, are bound by regulations that mandate the use of encryption for data protection. SSL/TLS helps organizations comply with these regulations.

SSLv3 vs. SSLv2

- Two early versions of this protocol were SSL Version 2 (v2) and SSL Version 3 (v3), which played an important role in the evolution of secure web communications.

SSL Version 2:

- Developed by Netscape (1995)
- First widely deployed version of SSL
- Now **obsolete and insecure**

Features

- Supports basic encryption using symmetric keys
- Uses public key cryptography for key exchange
- Provides server authentication (limited client authentication)
- Simple handshake mechanism

Working

- Client sends **ClientHello**
- Server responds with **ServerHello + Certificate**
- Client generates a session key
- Session key encrypted using server's public key
- Secure communication begins

Weaknesses of SSL v2

SSL v2 has serious design flaws:

- **Weak MAC construction** - Uses MD5 without proper security design
- **No handshake integrity protection** - Handshake messages can be tampered with
- **Same key for encryption and authentication**
- **No protection against replay attacks**
- Vulnerable to **Man-in-the-Middle (MITM)** attacks
- **Cipher suite negotiation is weak** (lacks proper protection and flexibility.)

SSL Version 3.0

- Released in 1996 as an improved version of SSL v2
- Major redesign to fix security issues
- Basis for modern TLS protocols

Features

- Stronger **handshake protocol**
- Separate keys for:
 - **Encryption**
 - **Message Authentication Code (MAC)**
- Supports multiple cipher suites
- Improved certificate handling
- Protection against replay attacks

SSL v3 Protocol Architecture

SSL v3 consists of two main layers:

A. SSL Record Protocol

Provides:

- Fragmentation
- Compression (optional)
- Integrity (MAC)
- Encryption

B. Higher-Level Protocols

- **Handshake Protocol** → Key exchange and authentication
- **ChangeCipherSpec Protocol** → Switch to secure mode
- **Alert Protocol** → Error reporting
- **Application Data Protocol** → Actual data transfer

SSL v3 Handshake Process

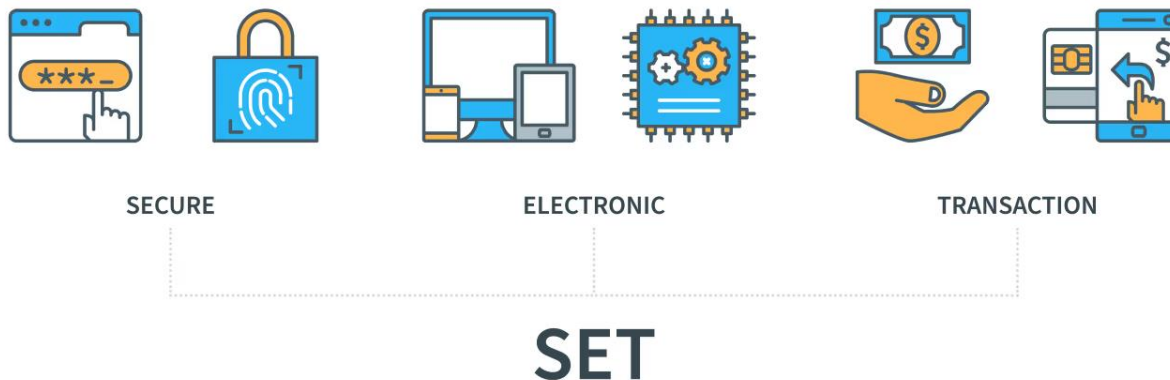
- **ClientHello**
 - Sends supported cipher suites, random number
- **ServerHello**
 - Chooses cipher suite, sends certificate
- **Key Exchange**
 - Client generates pre-master secret
 - Encrypts it using server's public key
- **Session Key Generation**
 - Both derive same session keys
- **ChangeCipherSpec**
 - Switch to encrypted communication
- **Finished Messages**
 - Verify handshake integrity

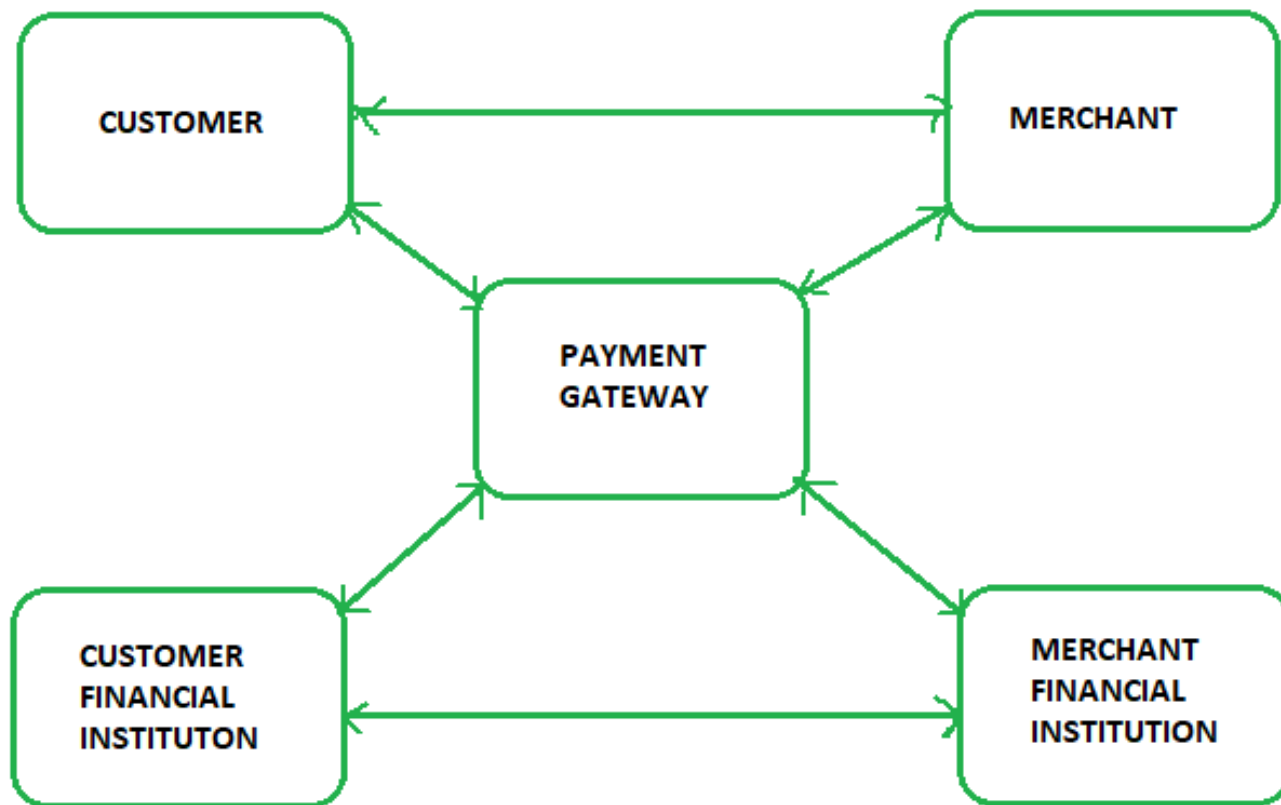
Comparison Between SSL v2 and SSL v3

Aspect	SSL v2	SSL v3
Security	Very weak	Improved but still weak
Handshake	Not secure	Secure
Integrity	Poor	Better
Attack resistance	Low	Moderate
Status	Deprecated	Deprecated

Secure Electronic Transaction (SET) Protocol

- **Secure Electronic Transaction (SET)** is a security protocol used to protect **credit card payments on the internet**.
- It is not a payment system itself, but a method to make online transactions secure.
- Uses **encryption and hashing** to protect payment data
- Developed with support from companies like Visa, MasterCard, Microsoft, and Netscape
- Keeps **credit card details hidden from merchants**, reducing fraud
- Uses **digital certificates (X.509)** issued by Certification Authorities for authentication





Requirements in SET:

- It has to provide mutual authentication i.e., **customer (or cardholder) authentication** by confirming if the customer is an intended user or not, and **merchant authentication**.
- It has to keep the **PI (Payment Information)** and **OI (Order Information)** confidential by appropriate encryptions.
- It has to be **resistive against message modifications** i.e., no changes should be allowed in the content being transmitted.
- SET also needs to provide **interoperability** and make use of the best security mechanisms.

Participants in SET:

In the general scenario of online transactions, SET includes similar participants:

- **Cardholder** – customer
- **Issuer** – customer financial institution
- **Merchant**
- **Acquirer** – Merchant financial
- **Certificate authority** – Authority that follows certain standards and issues certificates(like X.509V3) to all other participants.

SET Functionalities:

- **Authentication:**
 - **Merchant Authentication:** Verifies that the merchant is legitimate using **X.509 certificates**
 - **Customer Authentication:** Ensures the cardholder is authorized using **X.509 certificates**
- **Message Confidentiality:**
 - Protects data from unauthorized access using **encryption (DES)**
- **Message Integrity:**
 - Prevents data modification using **digital signatures (RSA with SHA-1 / HMAC-SHA-1)**

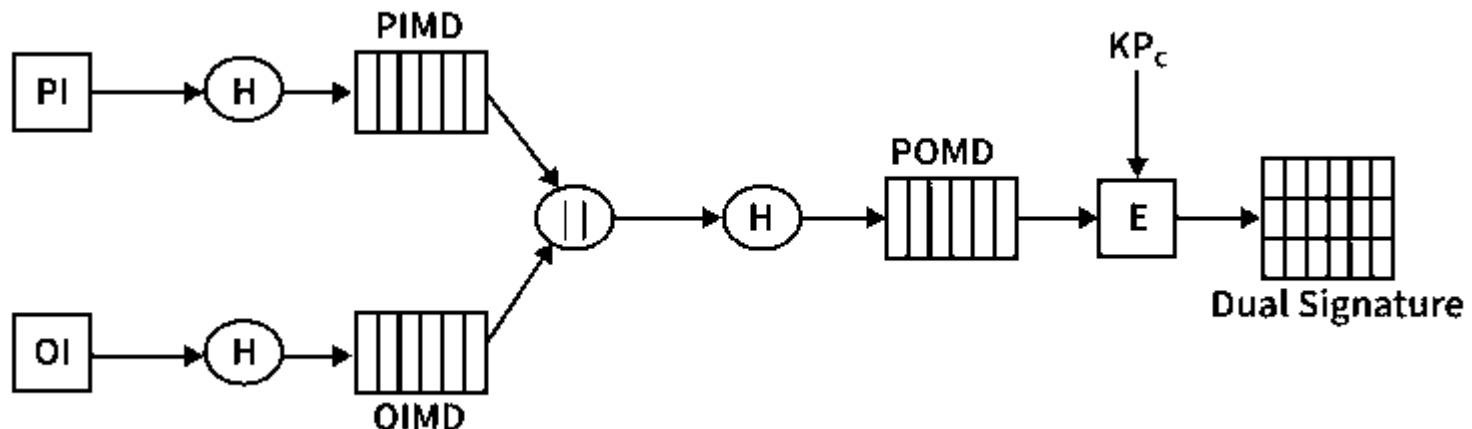
Dual Signature:

- The dual signature is a concept introduced with SET, which aims at connecting two information pieces meant for two different receivers :

Order Information (OI) for merchant

Payment Information (PI) for bank

- You might think sending them separately is an easy and more secure way, but sending them in a connected form resolves any future dispute possible. Here is the generation of dual signature:



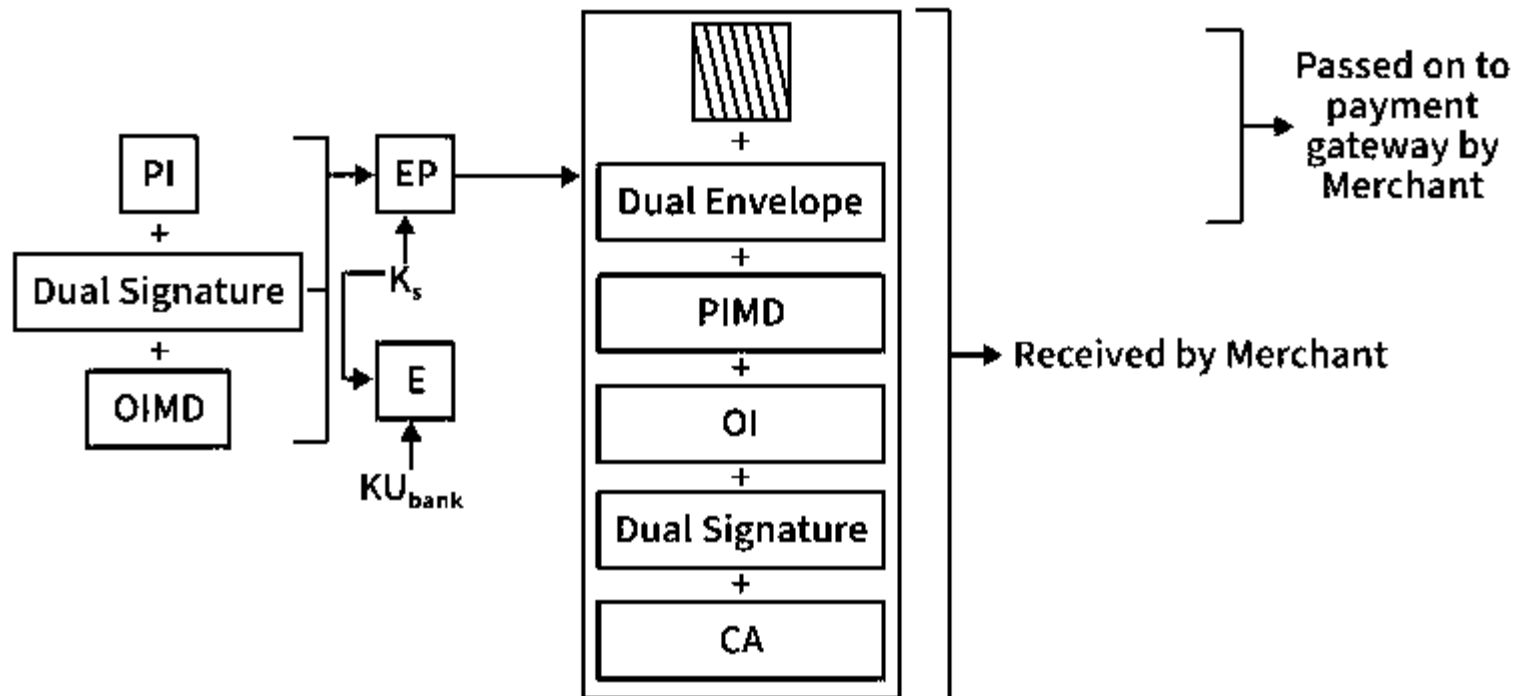
Where,

- PI stands for payment information
 - OI stands for order information
 - PIMD stands for Payment Information Message Digest
 - OIMD stands for Order Information Message Digest
 - POMD stands for Payment Order Message Digest
 - H stands for Hashing
 - E stands for public key encryption
 - KPc is customer's private key
 - || stands for append operation
- Dual signature, $DS = E(KPc, [H(H(PI) || H(OI))])$

Purchase Request Generation:

Inputs Required:

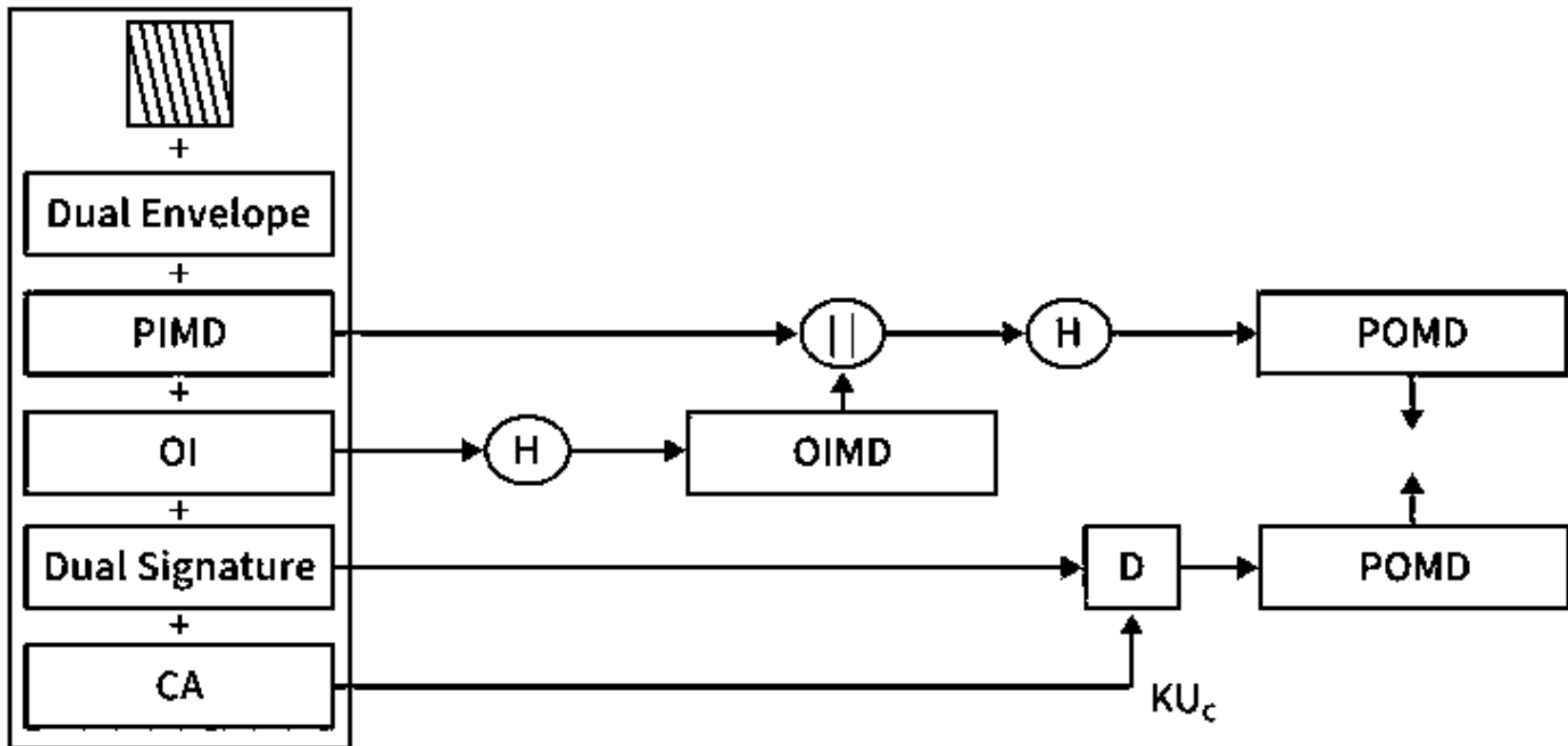
- **Payment Information (PI):** Contains sensitive payment details such as card number, expiry date, and transaction amount, which are intended only for the bank.
- **Dual Signature:** A security mechanism that links Order Information (OI) and Payment Information (PI) to ensure both belong to the same transaction while keeping each confidential.
- **Order Information Message Digest (OIMD):** A hash value of the order information that ensures the integrity of the order details.



Here, PI, OIMD, OI all have the same meanings as before.
The new things are :

- EP which is symmetric key encryption
- Ks is a temporary symmetric key
- KUbank is public key of bank
- CA is Cardholder or customer Certificate
- Digital Envelope = $E(KU_{bank}, K_s)$

- **Purchase Request Validation on Merchant Side:**
- The Merchant verifies by comparing POMD generated through PIMD hashing with POMD generated through decryption of Dual Signature as follows:



Payment Authorization & Capture

- **Payment Authorization:** Merchant verifies payment details to ensure the transaction is valid and funds are available.
- **Payment Capture:** Merchant sends a request to the payment gateway, which processes and transfers the payment.

Disadvantages of SET

- Too **complex** to implement and use
- Requires **special software** (digital wallets, card readers)
- **Slow and less user-friendly**
- **Compatibility and setup issues**
- Difficult use of **digital certificates (PKI)**
- Replaced by simpler protocols like **SSL / Transport Layer Security**

thank you